INTE/ISO/IEC 42001:2026

Tecnología de la información. Inteligencia artificial. Sistema de gestión.

Campo	Detalle
Correspondencia	Esta norma nacional es idéntica (IDT) a la norma internacional ISO/IEC 42001:2023 *“Information technology — Artificial intelligence — Management system”*
Fecha de aprobación	2026-01-13
Edición	Primera Edición
Secretaría	INTECO
ICS	35.020, 03.100.70
Editada e impresa por	© INTECO — Derechos reservados

AVISOS IMPORTANTES SOBRE ESTE DOCUMENTO

Las normas, los documentos normativos y otros instrumentos documentales de la Dirección de Normalización de INTECO, entre ellos el presente, son elaborados a través de un proceso de desarrollo de normas que se llevan a cabo bajo los principios de transparencia, apertura, imparcialidad, consenso, efectividad, relevancia, coherencia y dimensión del desarrollo, que emanan del Organismo Mundial de Comercio (OMC).

Ese proceso reúne a expertos voluntarios en distintas materias, integrados en comités que llevan el nombre del objeto de cada norma y representan distintas visiones.

Forman parte los consumidores, empresarios, el Estado, y otros interesados en la norma, que exponen diferentes puntos de vista e intereses para lograr el consenso de la norma; mientras que la Dirección de Normalización de INTECO coordina el proceso y establece reglas para promover la equidad en el consenso para aprobar cada norma. La Dirección de Normalización de INTECO no forma parte de ningún comité, no vota, ni evalúa o verifica el contenido de ninguna norma, solo facilita el proceso de desarrollo de esta.

Por ello, INTECO no se hace responsable por el contenido de cada norma aprobada en un órgano de estudio, ya que esa responsabilidad recae en los miembros que participaron y la aprobaron pues son los expertos en la materia objeto de la norma.

INTECO no aceptará responsabilidad alguna por la aplicación de una norma, en especial no la acepta sobre daño personal, o sobre las cosas o derechos, u otros de cualquier naturaleza, ya sean especiales, directos o indirectos como consecuencia de la utilización del presente documento. Tampoco por la calidad resultante del producto o servicio al cual aplica.

La Dirección de Normalización de INTECO tampoco garantiza la precisión o que la información aquí publicada esté completa. Al expedir y poner este documento a la disposición del público, la Dirección de Normalización de INTECO no se responsabiliza por la prestación de servicios profesionales o de alguna otra índole a nombre de cualquier otra persona o entidad. Si el interesado no es experto o duda del contenido de la norma, deberá buscar la ayuda de un profesional competente y capacitado para determinar el ejercicio razonable en cualquier circunstancia.

La Dirección de Normalización de INTECO, desde el proceso de desarrollo de normas, no tiene poder, ni responsabilidad, para vigilar o hacer cumplir los contenidos de este documento. Este proceso de desarrollo de normas no certifica, prueba o inspecciona productos, diseños o instalaciones en cumplimiento de ninguna norma. Cualquier certificación u otra declaración de cumplimiento con los requerimientos de este documento es únicamente responsabilidad del Ente Certificador o la persona o entidad que hace la declaración.

Las observaciones a este documento han de dirigirse a:

> *Instituto de Normas Técnicas de Costa Rica San Pedro de Montes de Oca, San José, Costa Rica Tel: +506 4080-6490 info@inteco.org — www.inteco.org*

El presente documento técnico pertenece a INTECO en virtud de los instrumentos nacionales e internacionales, y por criterios de la Organización Mundial de la Propiedad Intelectual (OMPI). Salvo por autorización expresa y escrita por parte de INTECO, no podrá reproducirse ni utilizarse ninguna parte de esta publicación bajo ninguna forma y por ningún procedimiento, electrónico o mecánico, fotocopias y microfilms inclusive, o cualquier sistema futuro para reproducir documentos. Todo irrespeto a los derechos de autor será denunciado ante las autoridades respectivas. Las solicitudes deben ser enviadas a la Dirección de Normalización de INTECO.

CONTENIDO

Sección	Título	Página
—	Avisos importantes sobre este documento	i
—	Prólogo	v
0	Introducción	vii
1	Objeto y campo de aplicación	1
2	Normas de referencia	1
3	Términos y definiciones	4
4	Contexto de la organización	13
5	Liderazgo	15
6	Planificación	16
7	Soporte	19
8	Operación	21
9	Evaluación del desempeño	22
10	Mejora	24
11	Correspondencia	25
Anexo A (Normativo)	Objetivos de control y controles de referencia	26
Anexo B (Normativo)	Guía de implementación de los controles de IA	31
Anexo C (Informativo)	Potenciales objetivos organizacionales y fuentes de riesgo relacionados con la IA	59
Anexo D (Informativo)	Uso del sistema de gestión de la IA en diferentes dominios o sectores	61
—	Bibliografía	63

PRÓLOGO

El Instituto de Normas Técnicas de Costa Rica, INTECO, es el Ente Nacional de Normalización, según la Ley N° 10473 del Sistema Nacional para la Calidad. Es una organización de carácter privado, sin ánimo de lucro, cuya función es el desarrollar las normas técnicas del país, siguiendo los principios de las buenas prácticas internacionales de normalización, basadas en los resultados consolidados de la experiencia, la ciencia y la tecnología. INTECO colabora con el sector gubernamental y apoya al sector privado del país, para lograr ventajas competitivas en los mercados interno y externo.

La representación de todos los sectores involucrados en el proceso de Normalización Técnica está garantizada por los Comités Técnicos y el periodo de Consulta Pública, este último caracterizado por la participación del público en general.

Esta norma INTE/ISO/IEC 42001:2026 fue aprobada por INTECO en la fecha del 2026-01-13.

Esta norma está sujeta a ser actualizada permanentemente con el objeto de que responda en todo momento a las necesidades y exigencias actuales.

A continuación, se mencionan las organizaciones que colaboraron en el estudio de esta norma a través de su participación en el Comité Técnico Nacional CTN 27 SC 05, Inteligencia Artificial.

Participante	Organización
Margoth Rojas Sánchez	Ministerio de Ciencia, Innovación, Tecnología y Telecomunicaciones (MICITT)
Marlon Avalos Elizondo	Ministerio de Ciencia, Innovación, Tecnología y Telecomunicaciones (MICITT)
Wendy Fiera Renán	Agencia de Protección de Datos de los Habitantes (PRODHAB)
Maria Laura Quesada Martínez	Instituto Costarricense de Electricidad (ICE)
Ricardo Morales Rojas	Banco Central de Costa Rica (BCCR)
Carlos Bernal Aristizábal	Cámara de Infocomunicación y Tecnología de Costa Rica (INFOCOM)
José Andrés Fernández Marmolejo	Colegio de Profesionales en Informática y Computación (CPIC)
Esura Alvarez Zamovski	Cámara de Tecnologías de la Información y Comunicación (CAMTIC)
César Oviedo Blanco	Cámara de Tecnologías de la Información y Comunicación (CAMTIC)
Jaime Figueres Ulate	Cámara de Tecnologías de la Información y Comunicación (CAMTIC)
Alvaro Solano Mena	Universidad Latina de Costa Rica
Jose Mauricio Herrera Pérez	Universidad Latina de Costa Rica
Luis Alexander Calvo Valverde	Instituto Tecnológico de Costa Rica (TEC)
Ricardo Villalón Fonseca	Universidad de Costa Rica (UCR)
Edgar Zamora Gatgens	Universidad CENFOTEC
Mariateresa Garrido Villareal	Universidad para la Paz de las Naciones Unidas
Luis Bustamante Ramírez	Universidad para la Paz de las Naciones Unidas
Jeannie Bonilla Oliva	TeKnowledge

Participante	Organización
Jean Paul Gutiérrez Buzano	Grant Thornton
Mariela Varela Campos	Grupo Purdy
Milena Grillo Rivera	Paniamor
Oscar Valverde Cerros	—

Gestor de proyectos de normalización: Jose Adrián Arroyo Aguilar

---

0 INTRODUCCIÓN

La inteligencia artificial (IA) se aplica cada vez más en todos los sectores que usan tecnologías de la información y se espera que sea uno de los principales motores económicos. Una consecuencia de esta tendencia es que algunas de sus aplicaciones puedan suscitar retos sociales en los próximos años.

Este documento pretende ayudar a las organizaciones a desempeñar de forma responsable su papel con respecto a los sistemas de IA (por ejemplo, utilizar, desarrollar, supervisar o proveer productos o servicios que utilicen IA). La IA genera posibles consideraciones específicas como:

- El uso de la IA para la toma de decisiones automatizada, a veces de forma no transparente ni explicable, puede requerir una gestión específica más allá de la gestión de los sistemas informáticos clásicos.
- El uso del análisis de datos, el descubrimiento y el aprendizaje automático, en lugar de la lógica codificada por humanos para diseñar sistemas, aumenta las oportunidades de aplicación de los sistemas de IA y al mismo tiempo cambia la forma en que dichos sistemas se desarrollan, justifican y despliegan.
- Los sistemas de IA que realizan un aprendizaje continuo cambian su comportamiento con el uso. Esto requiere una consideración especial para asegurar que su uso responsable continúe, aunque haya cambios de comportamiento.

Este documento proporciona los requisitos para establecer, implementar, mantener y mejorar continuamente un sistema de gestión de la IA en el contexto de una

organización. Se espera que las organizaciones enfoquen su aplicación de los requisitos a características propias de la IA. Ciertas características de la IA, como la capacidad de aprender y mejorar continuamente o la falta de transparencia o explicabilidad, pueden justificar salvaguardas diferentes si suscitan una preocupación adicional en comparación con la forma en que se realizaría tradicionalmente. La adopción de un sistema de gestión de la IA para ampliar las estructuras de gestión existentes es una decisión estratégica para una organización.

> ***Nota nacional:*** *Ver concepto explicabilidad (3.5.7) en la norma INTE/ISO/IEC 22989.*

Las necesidades y objetivos, procesos, tamaño y estructura de la organización, así como las expectativas de las distintas partes interesadas, influyen en el establecimiento e implementación del sistema de gestión de la IA. Otro conjunto de factores que influyen en el establecimiento e implementación del sistema de gestión de la IA son los numerosos casos de uso de la IA y la necesidad de encontrar el equilibrio adecuado entre los mecanismos de gobernanza y la innovación.

Las organizaciones pueden optar por aplicar estos requisitos utilizando un enfoque basado en el riesgo para asegurarse de que se aplica el nivel adecuado de control para los casos de uso, servicios o productos específicos de IA en el ámbito de la organización. Es de esperar que todos estos factores de influencia cambien y se revisen cada cierto tiempo.

El sistema de gestión de la IA debería integrarse en los procesos y la estructura general de gestión de la organización. Las cuestiones específicas relacionadas con la IA deberían tenerse en cuenta en el diseño de los procesos, los sistemas de información y los controles. Ejemplos cruciales de dichos procesos de gestión son:

- la determinación de los objetivos de la organización, implicación de las partes interesadas y política de la organización;
- la gestión del riesgo y oportunidades;
- los procesos para la gestión de las preocupaciones relacionadas con la fiabilidad de los sistemas de IA, tales como la protección de las personas y cosas, la seguridad, la equidad, la transparencia, la calidad de los datos y la calidad de los sistemas de IA durante su ciclo de vida;
- los procesos para la gestión de proveedores, socios y terceros que provean o desarrollen sistemas de IA para la organización.

Este documento proporciona directrices para el despliegue de controles aplicables para apoyar dichos procesos.

Este documento evita dar guías específicas sobre los procesos de gestión. La organización puede combinar marcos de trabajo generalmente aceptados, otras normas internacionales y su propia experiencia para implementar procesos cruciales como la gestión del riesgo, la gestión del ciclo de vida y la gestión de la calidad de los datos que sean apropiados para los casos de uso, productos o servicios específicos de IA dentro del ámbito de aplicación.

Una organización que cumpla con los requisitos de este documento puede generar evidencias de su responsabilidad y rendición de cuentas en relación con su papel respecto a los sistemas de IA.

El orden en que se presentan los requisitos en este documento no refleja su importancia ni implica el orden de su implementación. Los elementos listados se enumeran únicamente a efectos de referencia.

Compatibilidad con otras normas de sistemas de gestión

Este documento aplica la estructura armonizada (idénticos números de capítulo, títulos de capítulo, texto y términos comunes y definiciones básicas) desarrollada para potenciar el alineamiento entre las normas de sistemas de gestión (MSS, por sus siglas en inglés). El sistema de gestión de la IA proporciona requisitos específicos para gestionar los problemas y riesgos derivados del uso de la IA en una organización. Este enfoque común facilita la implementación y coherencia con otras normas sobre sistemas de gestión, por ejemplo, las relativas a calidad, protección de las personas y cosas, seguridad y privacidad.

---

1 OBJETO Y CAMPO DE APLICACIÓN

Este documento especifica los requisitos y proporciona una guía para establecer, implementar, mantener y mejorar continuamente un sistema de gestión de la IA (inteligencia artificial) en el contexto de una organización.

Este documento está destinado para ser utilizado por una organización que provea o use productos o servicios que utilicen sistemas de IA. Este documento pretende ayudar a la organización a desarrollar, proveer o usar sistemas de IA de forma

responsable en la consecución de sus objetivos y a cumplir los requisitos aplicables, las obligaciones relacionadas con las partes interesadas y las expectativas de éstas.

Este documento es aplicable a cualquier organización, independientemente de su tamaño, tipo y naturaleza, que provea o use productos o servicios que utilicen sistemas de IA.

---

2 NORMAS DE REFERENCIA

En el texto se hace referencia a los siguientes documentos de manera que parte o la totalidad de su contenido constituyen requisitos de este documento. Para las referencias con fecha, solo se aplica la edición citada. Para las referencias sin fecha se aplica la última edición (incluida cualquier modificación de esta).

> ***INTE/ISO/IEC 22989:2026*** *— Tecnología de la información — Inteligencia artificial — Conceptos y terminología de la inteligencia artificial.*

---

3 TÉRMINOS Y DEFINICIONES

Para los fines de este documento, se aplican los términos y definiciones incluidos en la Norma INTE/ISO/IEC 22989 además de los siguientes.

ISO e IEC mantienen bases de datos terminológicas para su utilización en normalización en las siguientes direcciones:

- Plataforma de búsqueda en línea de ISO: disponible en https://www.iso.org/obp
- Electropedia de IEC: disponible en https://www.electropedia.org/

3.1 organización

Persona o grupo de personas que tiene sus propias funciones con responsabilidades, autoridades y relaciones para el logro de sus objetivos (3.6).

> ***Nota 1.*** *El concepto de organización incluye, sin carácter exhaustivo, un trabajador independiente, compañía, corporación, firma, empresa, autoridad, sociedad,*

> *organización benéfica o institución, o una parte o combinación de estas, ya estén constituidas o no, públicas o privadas.*
>
> ***Nota 2.*** *Si la organización forma parte de una entidad más grande, el término "organización" se refiere únicamente a la parte de la entidad más grande que se encuentra dentro del alcance del sistema de gestión (3.4) de la IA.*

3.2 parte interesada

Persona u organización (3.1) que puede afectar, verse afectada o percibirse como afectada por una decisión o actividad.

> ***Nota 1.*** *En el apartado 5.19 de la Norma INTE/ISO/IEC 22989:2022, se proporciona una síntesis de las partes interesadas en lo referente a la IA.*

3.3 alta dirección

Persona o grupo de personas que dirige y controla una organización (3.1) al más alto nivel.

> ***Nota 1.*** *La alta dirección tiene el poder para delegar autoridad y proporcionar recursos dentro de la organización.*
>
> ***Nota 2.*** *Si el alcance del sistema de gestión (3.4) comprende solo una parte de una organización, entonces la alta dirección se refiere a quienes dirigen y controlan esa parte de la organización.*

3.4 sistema de gestión

Conjunto de elementos de una organización (3.1) interrelacionados o que interactúan para establecer políticas (3.5) y objetivos (3.6), así como procesos (3.8) para lograr estos objetivos.

> ***Nota 1.*** *Un sistema de gestión puede considerar una sola disciplina o varias disciplinas.*
>
> ***Nota 2.*** *Los elementos del sistema de gestión incluyen la estructura, los roles y las responsabilidades, la planificación y la operación de la organización.*

3.5 política

Intenciones y dirección de una organización (3.1), como las expresa formalmente su alta dirección (3.3).

3.6 objetivo

Resultado a lograr.

> ***Nota 1.*** *Un objetivo puede ser estratégico, táctico u operativo.*
>
> ***Nota 2.*** *Los objetivos pueden referirse a diferentes disciplinas (tales como finanzas, seguridad y salud y medio ambiente). Pueden ser, por ejemplo, para toda la organización, o para un proyecto, producto o proceso (3.8) específico.*
>
> ***Nota 3.*** *Un objetivo se puede expresar de otras maneras, por ejemplo, como un resultado previsto, un propósito, un criterio operativo, un objetivo de IA o mediante el uso de términos con un significado similar (por ejemplo, propósito, objetivo global o meta).*
>
> ***Nota 4.*** *En el contexto de sistemas de gestión (3.4) de la IA, la organización (3.1) establece los objetivos de IA, en coherencia con la política (3.5) de IA, para lograr resultados específicos.*

3.7 riesgo

Efecto de la incertidumbre.

> ***Nota 1.*** *Un efecto es una desviación de lo esperado, ya sea positivo o negativo.*
>
> ***Nota 2.*** *Incertidumbre es el estado, incluso parcial, de deficiencia de información relacionada con la comprensión o conocimiento de un evento, su consecuencia o su probabilidad.*
>
> ***Nota 3.*** *Con frecuencia el riesgo se caracteriza por referencia a eventos potenciales y consecuencias, o a una combinación de estos.*
>
> ***Nota 4.*** *Con frecuencia el riesgo se expresa en términos de una combinación de las consecuencias de un evento (incluidos cambios en las circunstancias) y la probabilidad asociada de que ocurra.*

3.8 proceso

Conjunto de actividades interrelacionadas o que interactúan, que usa o transforma las entradas para producir un resultado.

> ***Nota 1.*** *El hecho de que el resultado de un proceso se denomine una salida, un producto o un servicio depende del contexto de referencia.*

3.9 competencia

Capacidad para aplicar conocimientos y habilidades con el fin de lograr los resultados previstos.

3.10 información documentada

Información que una organización (3.1) tiene que controlar y mantener, y el medio de soporte que la contiene.

> ***Nota 1.*** *La información documentada puede estar en cualquier formato y medio de soporte, y puede provenir de cualquier fuente.*
>
> ***Nota 2.*** *La información documentada puede hacer referencia a: el sistema de gestión (3.4), incluidos los procesos (3.8) relacionados; la información generada para que la organización opere (documentación); la evidencia de los resultados alcanzados (registros).*

3.11 desempeño; rendimiento

Resultado medible.

> ***Nota 1.*** *El desempeño o rendimiento se puede relacionar con hallazgos cuantitativos o cualitativos.*
>
> ***Nota 2.*** *El desempeño se puede relacionar con la gestión de actividades, procesos (3.8), productos, servicios, sistemas u organizaciones (3.1).*
>
> ***Nota 3.*** *En el contexto de este documento, el rendimiento se refiere a los resultados logrados mediante el uso de sistemas de IA y el desempeño a los resultados relacionados con el sistema de gestión (3.4) de la IA. La interpretación correcta del término se desprende claramente de su contexto de uso.*

3.12 mejora continua

Actividad recurrente para mejorar el desempeño (3.11).

3.13 eficacia

Grado en el que se realizan las actividades planificadas y se logran los resultados planificados.

3.14 requisito

Necesidad o expectativa establecida, generalmente implícita u obligatoria.

> ***Nota 1.*** *"Generalmente implícita" significa que es habitual o práctica común para la organización (3.1) y las partes interesadas (3.2) que la necesidad o expectativa bajo consideración está implícita.*
>
> ***Nota 2.*** *Un requisito especificado es el que está declarado, por ejemplo, en información documentada (3.10).*

3.15 conformidad

Cumplimiento de un requisito (3.14).

3.16 no conformidad

Incumplimiento de un requisito (3.14).

3.17 acción correctiva

Acción para eliminar las causas de una no conformidad (3.16) y prevenir que vuelvan a ocurrir.

3.18 auditoría

Proceso (3.8) sistemático e independiente para obtener las evidencias y evaluarlas de manera objetiva con el fin de determinar el grado en el que se cumplen los criterios de auditoría.

> ***Nota 1.*** *Una auditoría puede ser interna (de primera parte), o externa (de segunda o tercera parte), y puede ser combinada (combinando dos o más disciplinas).*
>
> ***Nota 2.*** *Una auditoría interna la realiza la propia organización (3.1) o una parte externa en su nombre.*
>
> ***Nota 3.*** *"Evidencia de la auditoría" y "criterios de auditoría" se definen en la Norma INTE/ISO 19011.*

3.19 medición

Proceso (3.8) para determinar un valor.

3.20 seguimiento/monitoreo

Determinación del estado de un sistema, un proceso (3.8) o una actividad.

> ***Nota 1.*** *Para determinar el estado puede ser necesario verificar, supervisar u observar en forma crítica.*

3.21 control

<riesgo> Medida que mantiene y/o modifica un riesgo (3.7).

> ***Nota 1.*** *Los controles incluyen, pero no se limitan a cualquier proceso, política, dispositivo, práctica u otras condiciones y/o acciones que mantengan y/o modifiquen un riesgo.*
>
> ***Nota 2.*** *Los controles no siempre pueden producir el efecto de modificación previsto o asumido.*
>
> *[FUENTE: INTE/ISO 31000:2018, 3.8, modificado. Añadido <riesgo> como dominio de aplicación]*

3.22 órgano de gobierno

Persona o grupo de personas que es responsable del desempeño y la conformidad de la organización.

> ***Nota 1.*** *No todas las organizaciones, especialmente las pequeñas, tendrán un órgano de gobierno separado de la alta dirección.*

> ***Nota 2.*** *Un órgano de gobierno puede incluir, pero no se limita a, un consejo de administración, comisiones del consejo, consejo de supervisión, administradores o supervisores.*
>
> *[FUENTE: ISO/IEC 38500:2015, 2.9, modificado. Se han añadido las notas]*

3.23 seguridad de la información

Preservación de la confidencialidad, la integridad y la disponibilidad de la información.

> ***Nota 1.*** *Pudiendo, además, abarcar otras propiedades, como la autenticidad, la responsabilidad, el no repudio y la fiabilidad.*
>
> *[FUENTE: INTE/ISO/IEC 27000:2018, 3.28]*

3.24 evaluación del impacto del sistema de IA

Proceso formal y documentado mediante el cual una organización que desarrolla, provee o usa productos o servicios que utilizan inteligencia artificial identifica, evalúa y aborda los impactos sobre las personas, los grupos de personas o ambos.

3.25 calidad de los datos

Característica de los datos por la que estos cumplen los requisitos de datos de la organización para un contexto específico.

> *[FUENTE: ISO/IEC 5259-1, 3.4]*

3.26 declaración de aplicabilidad

Documentación de todos los controles (3.21) necesarios y justificación de la inclusión o exclusión de controles.

> ***Nota 1.*** *Puede que las organizaciones no requieran todos los controles enumerados en el anexo A o incluso pueden ampliar la lista del anexo A con controles adicionales establecidos por la propia organización.*
>
> ***Nota 2.*** *La organización debe documentar, de acuerdo con los requisitos de este documento, todos los riesgos identificados. Todos los riesgos identificados y las*

> *medidas de gestión del riesgo (controles) establecidas para abordarlos deben reflejarse en la declaración de aplicabilidad.*

---

4 CONTEXTO DE LA ORGANIZACIÓN

4.1 Comprensión de la organización y de su contexto

La organización debe determinar las cuestiones externas e internas que son relevantes para su propósito y que afectan a su capacidad para lograr los resultados previstos de su sistema de gestión de la IA.

La organización debe determinar si el cambio climático es una cuestión relevante.

La organización debe considerar el propósito previsto de los sistemas de IA que desarrolle, provea o use. La organización debe determinar sus roles con respecto a estos sistemas de IA.

> ***Nota 1.*** *Para comprender la organización y su contexto, puede ser útil que la organización determine su rol respecto al sistema de IA. Estos roles pueden incluir, pero no limitado a, uno o más de los siguientes:*
>
> - *proveedores de IA, incluidos proveedores de plataformas de IA, proveedores de productos o servicios de IA;*
> - *productores de IA, incluidos desarrolladores de IA, diseñadores de IA, operadores de IA, probadores y evaluadores de IA, implementadores de IA, profesionales del factor humano en la IA, expertos en el dominio, evaluadores del impacto de la IA, contratistas, profesionales de gobernanza y supervisión de IA;*
> - *clientes de IA, incluidos los usuarios de IA;*
> - *colaboradores de IA, incluidos los integradores de sistemas de IA y los proveedores de datos;*
> - *sujetos de la IA, incluidos los que son objeto de tratamiento de datos y otros sujetos afectados;*
> - *autoridades relevantes, incluidos legisladores y reguladores.*

La Norma INTE/ISO/IEC 22989 proporciona una descripción detallada de estos roles. Además, los tipos de roles y su relación con el ciclo de vida del sistema de IA también se describen en el marco de gestión del riesgo de IA del NIST. Los roles de la organización pueden determinar la aplicabilidad y el grado de aplicabilidad de los requisitos y controles de este documento.

> ***Nota 2.*** *Las cuestiones externas e internas que han de abordarse conforme a este capítulo pueden variar en función de los roles y la jurisdicción de la organización y su impacto en la capacidad de la organización para lograr los resultados previstos de su sistema de gestión de la IA. Estas cuestiones pueden incluir, sin carácter exhaustivo:*
>
> *a) consideraciones relativas al contexto externo, como:*
>
> 1. *los requisitos legales aplicables, incluidos los usos prohibidos de la IA;*
> 2. *las políticas, directrices y decisiones de los reguladores que afecten a la interpretación o la aplicación de los requisitos legales en el desarrollo y uso de sistemas de IA;*
> 3. *los incentivos o consecuencias asociados al propósito previsto y uso de los sistemas de IA;*
> 4. *la cultura, las tradiciones, los valores, las normas y la ética en relación con el desarrollo y uso de la IA;*
> 5. *el panorama competitivo y las tendencias de nuevos productos y servicios que utilizan sistemas de IA;*
>
> *b) consideraciones relativas al contexto interno, como:*
>
> 1. *el contexto, la gobernanza, los objetivos, las políticas y los procedimientos de la organización;*
> 2. *las obligaciones contractuales;*
> 3. *el propósito previsto del sistema de IA que desarrollar o usar.*
>
> ***Nota 3.*** *La determinación de roles puede fundamentarse en obligaciones relacionadas con las categorías de datos que procesa la organización (por ejemplo, responsable del procesamiento de información de identificación personal (IIP) o Controlador de la información de identificación personal (IIP) durante el procesamiento). Ver la Norma INTE/ISO/IEC 29100 para la IIP y los roles asociados.*

> *Los roles pueden basarse también en requisitos legales específicos de los sistemas de IA.*

4.2 Comprensión de las necesidades y expectativas de las partes interesadas

La organización debe determinar:

- las partes interesadas que son relevantes para el sistema de gestión de la IA;
- los requisitos relevantes de estas partes interesadas;
- cuáles de estos requisitos se abordarán mediante el sistema de gestión de la IA.

> ***Nota.*** *Las partes interesadas relevantes pueden tener requisitos relacionados con el cambio climático.*

4.3 Determinación del alcance del sistema de gestión de la IA

La organización debe determinar los límites y la aplicabilidad del sistema de gestión de la IA para establecer su alcance.

Cuando se determina este alcance, la organización debe considerar:

- las cuestiones externas e internas indicadas en el apartado 4.1;
- los requisitos indicados en el apartado 4.2.

El alcance debe estar disponible como información documentada.

El alcance del sistema de gestión de la IA debe determinar las actividades de la organización con respecto a los requisitos de este documento sobre el sistema de gestión de IA, el liderazgo, planificación, apoyo, operación, desempeño, evaluación, mejora, controles y objetivos.

4.4 Sistema de gestión de la IA

La organización debe establecer, implementar, mantener, mejorar continuamente y documentar un sistema de gestión de la IA, incluidos los procesos necesarios y sus interacciones, de acuerdo con los requisitos de este documento.

---

5 LIDERAZGO

5.1 Liderazgo y compromiso

La alta dirección debe demostrar su liderazgo y compromiso con respecto al sistema de gestión de la IA:

- asegurándose de que se establezcan la política de IA (ver apartado 5.2) y los objetivos de la IA (ver apartado 6.2) y que estos sean compatibles con la dirección estratégica de la organización;
- asegurándose de la integración de los requisitos del sistema de gestión de la IA en los procesos de negocio de la organización;
- asegurándose de que los recursos necesarios para el sistema de gestión de la IA estén disponibles;
- comunicando la importancia de una gestión de la IA eficaz y de cumplir con los requisitos del sistema de gestión de la IA;
- asegurándose de que el sistema de gestión de la IA logre los resultados previstos;
- dirigiendo y apoyando a las personas para contribuir a la eficacia del sistema de gestión de la IA;
- promoviendo la mejora continua;
- apoyando otros roles relevantes para demostrar que su liderazgo se aplica a sus áreas de responsabilidad.

> ***Nota 1.*** *En este documento se puede interpretar el término "negocio" en su sentido más amplio para referirse a aquellas actividades que son esenciales para la existencia de la organización.*
>
> ***Nota 2.*** *Establecer, fomentar y modelar una cultura en la organización para adoptar un enfoque responsable respecto al uso, el desarrollo y el gobierno de los sistemas de IA puede ser una importante demostración de compromiso y liderazgo por parte de la alta dirección. Asegurarse de la concienciación y el cumplimiento de este enfoque responsable en apoyo del sistema de gestión de la IA a través del liderazgo puede contribuir al éxito del sistema de gestión de la IA.*

5.2 Política de IA

La alta dirección debe establecer una política de IA que:

a) sea apropiada al propósito de la organización; b) proporcione un marco de referencia para el establecimiento de los objetivos de la IA (ver apartado 6.2); c) incluya el compromiso de cumplir los requisitos aplicables; d) incluya el compromiso de mejora continua del sistema de gestión de la IA.

La política de IA debe:

- estar disponible como información documentada;
- referenciar, cuando sea relevante, a otras políticas organizacionales;
- comunicarse dentro de la organización;
- estar disponible para las partes interesadas, según corresponda.

Los objetivos de control y los controles para establecer una política de IA figuran en el capítulo A.2 de la tabla A.1. Las guías de implementación figuran en el capítulo B.2.

> ***Nota.*** *En la Norma INTE/ISO/IEC 38507 se proporcionan consideraciones para las organizaciones a la hora de desarrollar políticas de IA.*

5.3 Roles, responsabilidades y autoridades

La alta dirección debe asegurarse de que las responsabilidades y autoridades para los roles relevantes se asignen y comuniquen dentro de la organización.

La alta dirección debe asignar la responsabilidad y autoridad para:

a) asegurar que el sistema de gestión de la IA es conforme con los requisitos de este documento; b) informar a la alta dirección sobre el desempeño del sistema de gestión de la IA.

> ***Nota.*** *En el apartado A.3.2 de la tabla A.1 se facilita un control para definir y asignar roles y responsabilidades. En el apartado B.3.2 se proporciona una guía para la implementación de este control.*

---

6 PLANIFICACIÓN

6.1 Acciones para abordar riesgos y oportunidades

6.1.1 Generalidades

Al planificar el sistema de gestión de la IA, la organización debe considerar las cuestiones referidas en el apartado 4.1 y los requisitos referidos en el apartado 4.2, y determinar los riesgos y oportunidades que es necesario abordar con el fin de:

- asegurar que el sistema de gestión de la IA pueda lograr los resultados previstos;
- prevenir o reducir efectos no deseados;
- lograr la mejora continua.

La organización debe establecer y mantener criterios de riesgo relativos a la IA que permitan:

- distinguir los riesgos aceptables de los no aceptables;
- realizar evaluaciones del riesgo del uso de la IA;
- tratar el riesgo del uso de la IA;
- evaluar el impacto de los riesgos de la IA.

> ***Nota 1.*** *Las consideraciones para determinar la cantidad y el tipo de riesgo que una organización está dispuesta a asumir o aceptar se proporcionan en las Normas INTE/ISO/IEC 38507 e ISO/IEC 23894.*

La organización debe determinar los riesgos y oportunidades según:

- el ámbito y el contexto de aplicación de un sistema de IA;
- el uso previsto;
- los contextos externo e interno descritos en el apartado 4.1.

> ***Nota 2.*** *Se puede considerar más de un sistema de IA en el alcance del sistema de gestión de la IA. En ese caso, la determinación de oportunidades y usos se realiza para cada sistema o grupos de sistemas de IA.*

La organización debe planificar:

a) las acciones para abordar estos riesgos y oportunidades; b) la manera de:

1. integrar e implementar las acciones en sus procesos del sistema de gestión de la IA;
2. evaluar la eficacia de estas acciones.

La organización debe conservar información documentada sobre las acciones adoptadas para identificar y abordar los riesgos y las oportunidades de la IA.

> ***Nota 3.*** *En la Norma ISO/IEC 23894 se proporcionan guías sobre cómo implantar la gestión del riesgo en las organizaciones que desarrollan, proveen o utilizan productos, sistemas y servicios de IA.*
>
> ***Nota 4.*** *El contexto de la organización y sus actividades pueden influir en las actividades de gestión del riesgo de la organización.*
>
> ***Nota 5.*** *La forma de definir el riesgo y, en consecuencia, de concebir la gestión del riesgo puede variar según el sector y tipo de industria. La definición de riesgo del apartado 3.7 permite una visión amplia del riesgo adaptable a cualquier sector, como los mencionados en el anexo D.*

6.1.2 Evaluación del riesgo de la IA

La organización debe definir y establecer un proceso de evaluación del riesgo de la IA que:

a) se base y alinee con la política de IA (ver apartado 5.2) y los objetivos de la IA (ver apartado 6.2);

> ***Nota.*** *Al evaluar las consecuencias como parte del apartado 6.1.2 d) 1), la organización puede utilizar una evaluación del impacto del sistema de IA como se indica en el apartado 6.1.4.*

b) esté diseñado de tal modo que las evaluaciones reiteradas de los riesgos de la IA puedan producir resultados coherentes, válidos y comparables; c) identifique los riesgos que ayudan o impiden el logro de sus objetivos de la IA; d) analice los riesgos de la IA para:

1. evaluar las posibles consecuencias para la organización, las personas y la sociedad que se derivarían de la materialización de los riesgos identificados;
2. evaluar, en su caso, la probabilidad realista de los riesgos identificados;

3. determinar los niveles de riesgo; e) evalúe los riesgos de la IA para:
4. comparar los resultados del análisis del riesgo con los criterios de riesgo (ver apartado 6.1.1);
5. priorizar los riesgos evaluados para su tratamiento.

La organización debe conservar información documentada sobre el proceso de evaluación del riesgo de la IA.

6.1.3 Tratamiento del riesgo de la IA

Teniendo en cuenta los resultados de la evaluación del riesgo, la organización debe definir un proceso de tratamiento del riesgo de la IA para:

a) seleccionar las opciones adecuadas para el tratamiento del riesgo de la IA; b) determinar todos los controles necesarios para implementar las opciones elegidas de tratamiento del riesgo de la IA y comparar estos controles con los del anexo A para verificar que no se haya omitido ningún control necesario;

> ***Nota 1.*** *El anexo A proporciona controles de referencia para cumplir los objetivos de la organización y abordar los riesgos relacionados con el diseño y uso de los sistemas de IA.*

c) considerar los controles del anexo A que sean relevantes para la implementación de las opciones de tratamiento del riesgo de la IA; d) identificar si son necesarios controles adicionales a los del anexo A para implementar todas las opciones de tratamiento del riesgo; e) considerar las guías del anexo B para la implementación de los controles especificados en los puntos b) y c);

> ***Nota 2.*** *Los objetivos de control están incluidos implícitamente en los controles escogidos. La organización puede seleccionar un conjunto apropiado de objetivos de control y de controles del anexo A. Los controles del anexo A no son exhaustivos y pueden ser necesarios objetivos de control y controles adicionales. Si se necesitan controles diferentes o adicionales a los del anexo A, la organización puede diseñar esos controles o tomarlos de fuentes existentes. La gestión del riesgo de la IA puede integrarse en otros sistemas de gestión, si procede.*

f) elaborar una declaración de aplicabilidad que contenga los controles necesarios [ver b), c) y d)] y justificar la inclusión o exclusión de controles. La justificación de la exclusión puede incluir los casos en que la evaluación del riesgo no considere

necesarios los controles y los casos en que los requisitos externos aplicables no los exijan (o contemplen excepciones para ellos);

> ***Nota 3.*** *La organización puede proporcionar justificaciones documentadas para excluir cualquier objetivo de control en general o respecto a sistemas de IA específicos, ya sean los enumerados en el anexo A o los que establezca la propia organización.*

g) formular un plan de tratamiento del riesgo de la IA.

La organización debe obtener la aprobación de la gerencia designada para el plan de tratamiento de los riesgos de la IA y para la aceptación de los riesgos residuales de la IA. Los controles necesarios deben estar:

- alineados con los objetivos del apartado 6.2;
- disponibles como información documentada;
- comunicados dentro de la organización;
- disponibles para las partes interesadas, según corresponda.

La organización debe conservar información documentada sobre el proceso de tratamiento del riesgo de la IA.

6.1.4 Evaluación del impacto del sistema de IA

La organización debe definir un proceso para evaluar las consecuencias potenciales para las personas, los grupos de personas y la sociedad que puedan derivarse del desarrollo, suministro o uso de sistemas de IA.

La evaluación del impacto del sistema de IA debe determinar las consecuencias potenciales que el despliegue de un sistema de IA, así como su uso previsto o un uso inadecuado previsible tengan sobre las personas, los grupos de personas y la sociedad.

La evaluación del impacto del sistema de IA debe tener en cuenta el contexto técnico y social específico en el que se despliega el sistema de IA y las jurisdicciones aplicables.

El resultado de la evaluación del impacto del sistema de IA debe documentarse. Cuando proceda, el resultado de la evaluación del impacto del sistema puede ponerse a disposición de las partes interesadas relevantes que defina la organización.

La organización debe tener en cuenta los resultados de la evaluación del impacto del sistema de IA en la evaluación del riesgo (ver apartado 6.1.2). El apartado A.5 de la tabla A.1 proporciona controles para evaluar los impactos de los sistemas de IA.

> ***Nota.*** *En algunos contextos (como los sistemas de IA críticos para la protección de personas y cosas o la privacidad), la organización puede exigir que se realicen evaluaciones del impacto del sistema de IA específicas para cada disciplina (por ejemplo, impacto en la seguridad, la privacidad o la protección de personas y cosas) como parte de las actividades generales de gestión del riesgo de una organización.*

6.2 Objetivos de la IA y planificación para lograrlos

La organización debe establecer objetivos de la IA para las funciones y niveles relevantes.

Los objetivos de la IA deben:

a) ser consistentes con la política de IA (ver apartado 5.2); b) ser medibles (si es posible); c) tener en cuenta los requisitos aplicables; d) ser objeto de seguimiento; e) comunicarse; f) actualizarse, según corresponda; g) estar disponibles como información documentada.

Al planificar cómo lograr sus objetivos de la IA, la organización debe determinar:

- qué se va a hacer;
- qué recursos se requerirán;
- quién será responsable;
- cuándo se finalizará;
- cómo se evaluarán los resultados.

> ***Nota.*** *En el anexo C figura una lista no exhaustiva de objetivos de la IA relativos a la gestión del riesgo. En los apartados A.6.1 y A.9.3 de la tabla A.1 figuran los objetivos de control y los controles para identificar los objetivos de desarrollo y uso responsables de los sistemas de IA, así como las medidas para lograrlos. En los apartados B.6.1 y B.9.3 se facilitan guías para la implementación de estos controles.*

6.3 Planificación de cambios

Cuando la organización determine la necesidad de cambios en el sistema de gestión de la IA, los cambios deben llevarse a cabo de manera planificada.

---

7 SOPORTE

7.1 Recursos

La organización debe determinar y proporcionar los recursos necesarios para el establecimiento, implementación, mantenimiento y mejora continua del sistema de gestión de la IA.

> ***Nota.*** *En el apartado A.4 de la tabla A.1 figuran los objetivos de control y los controles para los recursos de la IA. En el apartado B.4 se facilita una guía de implementación de estos controles.*

7.2 Competencia

La organización debe:

- determinar la competencia necesaria de las personas que realizan, bajo su control, un trabajo que afecta al desempeño de la IA;
- asegurar que estas personas sean competentes, basándose en la educación, formación o experiencia apropiadas;
- cuando sea aplicable, tomar acciones para adquirir la competencia necesaria y evaluar la eficacia de las acciones tomadas.

Debe estar disponible la información documentada apropiada como evidencia de la competencia.

> ***Nota 1.*** *En el apartado B.4.6 se facilita una guía para la implementación en lo referente a recursos humanos, incluidas consideraciones sobre los conocimientos especializados necesarios.*
>
> ***Nota 2.*** *Las acciones aplicables pueden incluir, por ejemplo, la formación, la tutoría o la reasignación de las personas empleadas actualmente; o la contratación de*

> *personas competentes.*

7.3 Concienciación

Las personas que realizan el trabajo bajo el control de la organización deben tomar conciencia de:

- la política de IA (ver apartado 5.2);
- su contribución a la eficacia del sistema de gestión de la IA, incluidos los beneficios de una mejora del desempeño de la IA;
- las implicaciones de no cumplir con los requisitos del sistema de gestión de la IA.

7.4 Comunicación

La organización debe determinar las comunicaciones internas y externas relevantes para el sistema de gestión de la IA, que incluyan:

- qué comunicar;
- cuándo comunicar;
- a quién comunicar;
- cómo comunicar.

7.5 Información documentada

7.5.1 Generalidades

El sistema de gestión de la IA de la organización debe incluir:

a) la información documentada requerida por este documento; b) la información documentada que la organización determine como necesaria para la eficacia del sistema de gestión de la IA.

> ***Nota.*** *La extensión de la información documentada para un sistema de gestión de la IA puede variar de una organización a otra, debido a: el tamaño de la organización y su tipo de actividades, procesos, productos y servicios; la complejidad de los procesos y sus interacciones; la competencia de las personas.*

7.5.2 Creación y actualización de la información documentada

Al crear y actualizar la información documentada, la organización debe asegurarse de que lo siguiente sea apropiado:

- la identificación y descripción (por ejemplo, título, fecha, autor o número de referencia);
- el formato (por ejemplo, idioma, versión del software, gráficos) y los medios de soporte (por ejemplo, papel, electrónico);
- la revisión y aprobación con respecto a la idoneidad y adecuación.

7.5.3 Control de la información documentada

La información documentada requerida por el sistema de gestión de la IA y por este documento se debe controlar para asegurar que:

a) esté disponible y sea idónea para su uso, dónde y cuándo se necesite; b) esté protegida adecuadamente (por ejemplo, contra la pérdida de la confidencialidad, uso inadecuado, o pérdida de integridad).

Para el control de la información documentada, la organización debe abordar las siguientes actividades, según corresponda:

- distribución, acceso, recuperación y uso;
- almacenamiento y preservación, incluida la preservación de la legibilidad;
- control de cambios (por ejemplo, control de versión);
- conservación y disposición final.

La información documentada de origen externo que la organización determina como necesaria para la planificación y operación del sistema de gestión de la IA se debe identificar, según sea apropiado, y controlar.

> ***Nota.*** *El acceso puede implicar una decisión con relación al permiso solamente para consultar la información documentada, o al permiso y a la autoridad para consultar y modificar la información documentada.*

---

8 OPERACIÓN

8.1 Planificación y control operacional

La organización debe planificar, implementar y controlar los procesos necesarios para cumplir los requisitos y para implementar las acciones determinadas en el capítulo 6 mediante:

- el establecimiento de criterios para los procesos;
- la implementación del control de los procesos de acuerdo con los criterios.

La organización debe implementar los controles establecidos según el apartado 6.1.3 que estén relacionados con la operación del sistema de gestión de la IA (por ejemplo, controles relacionados con el ciclo de vida del desarrollo y uso del sistema de IA).

Se debe supervisar la eficacia de estos controles y se deben tomar en consideración acciones correctivas si no se logran los resultados previstos. En el anexo A se enumeran los controles de referencia y en el anexo B se facilita una guía sobre su implementación.

Debe estar disponible la información documentada en la medida necesaria para tener confianza en que los procesos se han llevado a cabo según lo planificado.

La organización debe controlar los cambios planificados y revisar las consecuencias de los cambios no previstos, tomando acciones para mitigar cualquier efecto adverso, según sea necesario.

La organización debe asegurarse de que se controlen los procesos, productos o servicios suministrados externamente que son relevantes para el sistema de gestión de la IA.

8.2 Evaluación del riesgo de la IA

La organización debe realizar evaluaciones del riesgo de la IA según el apartado 6.1.2 a intervalos planificados o cuando se propongan o produzcan cambios significativos.

La organización debe conservar información documentada de los resultados de todas las evaluaciones del riesgo de la IA.

8.3 Tratamiento del riesgo de la IA

La organización debe aplicar el plan de tratamiento del riesgo de la IA según el apartado 6.1.3 y verificar su eficacia.

Cuando las evaluaciones del riesgo identifiquen nuevos riesgos que requieran tratamiento, se debe llevar a cabo un proceso de tratamiento de esos riesgos según el apartado 6.1.

Cuando las opciones de tratamiento del riesgo definidas en el plan de tratamiento del riesgo no sean eficaces, deben revisarse y revalidarse siguiendo el proceso de tratamiento del riesgo según lo indicado en el apartado 6.1.3, lo cual implica la correspondiente actualización del plan de tratamiento del riesgo.

La organización debe conservar información documentada de los resultados de todos los tratamientos del riesgo de la IA.

8.4 Evaluación del impacto del sistema de IA

La organización debe realizar evaluaciones del impacto del sistema de IA según el apartado 6.1.4 a intervalos planificados o cuando se propongan o produzcan cambios significativos.

La organización debe conservar información documentada de los resultados de todas las evaluaciones del impacto del sistema de IA.

---

9 EVALUACIÓN DEL DESEMPEÑO

9.1 Monitoreo, medición, análisis y evaluación

La organización debe determinar:

- qué necesita monitoreo y medición;
- los métodos de monitoreo, medición, análisis y evaluación, según sea aplicable, para asegurar resultados válidos;
- cuándo se deben llevar a cabo el monitoreo y la medición;
- cuándo se deben analizar y evaluar los resultados del monitoreo y la medición.

Debe estar disponible la información documentada como evidencia de los resultados.

La organización debe evaluar el desempeño y la eficacia del sistema de gestión de la IA.

9.2 Auditoría interna

9.2.1 Generalidades

La organización debe llevar a cabo auditorías internas a intervalos planificados para proporcionar información acerca de si el sistema de gestión de la IA:

a) es conforme con:

1. los requisitos propios de la organización para su sistema de gestión de la IA;
2. los requisitos de este documento; b) se implementa y mantiene eficazmente.

9.2.2 Programa de auditoría interna

La organización debe planificar, establecer, implementar y mantener uno o varios programas de auditoría que incluyan la frecuencia, los métodos, las responsabilidades, los requisitos de planificación y la elaboración de informes.

Al establecer los programas de auditoría, la organización debe considerar la importancia de los procesos involucrados y los resultados de las auditorías previas.

La organización debe:

a) definir los objetivos, criterios y el alcance de cada auditoría; b) seleccionar los auditores y llevar a cabo auditorías para asegurarse de la objetividad y la imparcialidad del proceso de auditoría; c) asegurar que los resultados de las auditorías se comunican a las personas relevantes de la alta dirección.

Debe estar disponible la información documentada como evidencia de la implementación de los programas de auditoría y de los resultados de las auditorías.

9.3 Revisión por la alta dirección

9.3.1 Generalidades

La alta dirección debe revisar el sistema de gestión de la IA de la organización a intervalos planificados para asegurar su continua idoneidad, adecuación y eficacia.

9.3.2 Insumos para la revisión por la alta dirección

La revisión por parte de la alta dirección debe incluir consideración de:

a) el estado de las acciones de las revisiones por la alta dirección previas; b) los cambios en las cuestiones externas e internas que sean relevantes para el sistema de gestión de la IA; c) los cambios en las necesidades y expectativas de las partes interesadas que sean relevantes para el sistema de gestión de la IA; d) la información sobre el desempeño del sistema de gestión de la IA, incluidas las tendencias relativas a:

1. no conformidades y acciones correctivas;
2. resultados de monitoreo y medición;
3. resultados de las auditorías; e) las oportunidades de mejora continua.

9.3.3 Resultados de la revisión por la alta dirección

Los resultados de la revisión por la alta dirección deben incluir las decisiones relacionadas con las oportunidades de mejora continua y cualquier necesidad de cambios en el sistema de gestión de la IA.

Debe estar disponible la información documentada como evidencia de los resultados de las revisiones por la alta dirección.

---

10 MEJORA

10.1 Mejora continua

La organización debe mejorar continuamente la idoneidad, adecuación y eficacia del sistema de gestión de la IA.

10.2 No conformidad y acción correctiva

Cuando ocurra una no conformidad, la organización debe:

a) reaccionar ante la no conformidad, y según sea aplicable:

1. tomar acciones para controlarla y corregirla;
2. hacer frente a las consecuencias; b) evaluar la necesidad de acciones para eliminar las causas de la no conformidad, con el fin de que no vuelva a ocurrir ni ocurra en otra parte, mediante:
3. la revisión de la no conformidad;
4. la determinación de las causas de la no conformidad;
5. la determinación de si existen no conformidades similares, o que potencialmente podrían ocurrir; c) implementar cualquier acción necesaria; d) revisar la eficacia de cualquier acción correctiva tomada; e) si es necesario, hacer cambios en el sistema de gestión de la IA.

Las acciones correctivas deben ser apropiadas a los efectos de las no conformidades encontradas.

Debe estar disponible la información documentada como evidencia de:

- la naturaleza de las no conformidades y cualquier acción tomada posteriormente;
- los resultados de cualquier acción correctiva.

---

11 CORRESPONDENCIA

Esta norma nacional es idéntica (IDT) a la norma internacional ISO/IEC 42001:2023 *“Information technology — Artificial intelligence — Management system”*.

ANEXO A (NORMATIVO) — OBJETIVOS DE CONTROL Y CONTROLES DE REFERENCIA

A.1 Generalidades

Los controles detallados en la tabla A.1 proporcionan a la organización una referencia para cumplir los objetivos organizacionales y abordar los riesgos relacionados con el diseño y la operación de los sistemas de IA. No se requiere utilizar todos los objetivos de control y los controles enumerados en la tabla A.1, y la organización puede diseñar e implementar sus propios controles (ver apartado 6.1.3).

El anexo B facilita una guía de implementación para todos los controles enumerados en la tabla A.1.

Tabla A.1 — Objetivos de control y controles de referencia

A.2 Políticas relativas a la IA

Objetivo: Proporcionar dirección y apoyo en materia de gestión para los sistemas de IA de acuerdo con los requisitos del negocio.

N.°	Control
A.2.2	**Política de IA.** La organización debe documentar una política para el desarrollo o el uso de sistemas de IA.
A.2.3	**Alineamiento con otras políticas organizacionales.** La organización debe determinar en qué medida otras políticas pueden verse afectadas por, o aplicarse a, los objetivos de la organización con respecto a los sistemas de IA.
A.2.4	**Revisión de la política de IA.** La política de IA se debe revisar a intervalos planificados o con una frecuencia adicional, según sea necesario, para asegurar su continua idoneidad, adecuación y eficacia.

A.3 Organización interna

Objetivo: Establecer la rendición de cuentas dentro de la organización para mantener su enfoque responsable en la implementación, operación y gestión de los sistemas de

IA.

N.°	Control
A.3.2	**Roles y responsabilidades en materia de IA.** Los roles y las responsabilidades en materia de IA se deben definir y asignar de acuerdo con las necesidades de la organización.
A.3.3	**Reporte de preocupaciones.** La organización debe definir y poner en marcha un proceso para notificar las preocupaciones sobre el rol de la organización con respecto a un sistema de IA durante todo su ciclo de vida.

A.4 Recursos para los sistemas de IA

Objetivo: Asegurar que la organización rinda cuentas de los recursos (incluidos los componentes y activos del sistema de IA) del sistema de IA para comprender y abordar plenamente los riesgos e impactos.

N.°	Control
A.4.2	**Documentación de los recursos.** La organización debe identificar y documentar los recursos relevantes que se requieren para las actividades en determinadas etapas del ciclo de vida del sistema de IA, así como para otras actividades relacionadas con la IA que sean relevantes para la organización.
A.4.3	**Recursos de datos.** Como parte de la identificación de los recursos, la organización debe documentar la información acerca de los recursos de datos utilizados para el sistema de IA.
A.4.4	**Recursos de herramientas.** Como parte de la identificación de los recursos, la organización debe documentar información acerca de los recursos de herramientas utilizados para el sistema de IA.
A.4.5	**Recursos del sistema y de computación.** Como parte de la identificación de los recursos, la organización debe documentar información acerca de los recursos del sistema y de computación utilizados para el sistema de IA.
A.4.6	**Recursos humanos.** Como parte de la identificación de los recursos, la organización debe documentar información acerca de los recursos humanos y sus competencias utilizados para el desarrollo, despliegue, operación, gestión de cambios, mantenimiento, transferencia y retirada del servicio, así como la verificación e integración del sistema de IA.

A.5 Evaluación de los impactos de los sistemas de IA

Objetivo: Evaluar los impactos del sistema de IA sobre las personas, los grupos de personas y la sociedad que se ven afectados por el sistema de IA durante todo su ciclo de vida.

N.°	Control
A.5.2	**Proceso de evaluación del impacto del sistema de IA.** La organización debe establecer un proceso para evaluar las consecuencias potenciales para las personas, los grupos de personas y la sociedad, que pueden derivarse del sistema de IA durante todo su ciclo de vida.
A.5.3	**Documentación de las evaluaciones del impacto del sistema de IA.** La organización debe documentar los resultados de las evaluaciones del impacto del sistema de IA y conservar los resultados durante un periodo de tiempo determinado.
A.5.4	**Evaluación del impacto del sistema de IA sobre las personas o grupos de personas.** La organización debe evaluar y documentar los impactos potenciales de los sistemas de IA sobre las personas o grupos de personas durante todo el ciclo de vida del sistema.
A.5.5	**Evaluación de los impactos sociales de los sistemas de IA.** La organización debe evaluar y documentar los impactos sociales potenciales de sus sistemas de IA durante todo su ciclo de vida.

A.6 Ciclo de vida del sistema de IA

A.6.1 — Guía sobre la gestión para el desarrollo de sistemas de IA

Objetivo: Asegurar que la organización identifique y documente objetivos e implemente procesos para el diseño y desarrollo responsables de sistemas de IA.

N.°	Control
A.6.1.2	**Objetivos para el desarrollo responsable del sistema de IA.** La organización debe identificar y documentar objetivos para guiar el desarrollo responsable de los sistemas de IA, así como tener en cuenta esos objetivos e integrar medidas para lograrlos en el ciclo de vida del desarrollo.
A.6.1.3	**Procesos para el diseño y desarrollo responsables de sistemas de IA.** La organización debe definir y documentar los procesos específicos para el diseño y desarrollo responsables del sistema de IA.

A.6.2 — Ciclo de vida del sistema de IA

Objetivo: Definir los criterios y requisitos para cada etapa del ciclo de vida del sistema de IA.

N.°	Control
A.6.2.2	**Requisitos y especificación del sistema de IA.** La organización debe especificar y documentar los requisitos para nuevos sistemas de IA o mejoras sustanciales de los sistemas existentes.
A.6.2.3	**Documentación del diseño y desarrollo del sistema de IA.** La organización debe documentar el diseño y desarrollo del sistema de IA sobre la base de los objetivos organizacionales, los requisitos documentados y los criterios de especificación.
A.6.2.4	**Verificación y validación del sistema de IA.** La organización debe definir y documentar las medidas de verificación y validación para el sistema de IA, así como especificar los criterios para su uso.
A.6.2.5	**Despliegue del sistema de IA.** La organización debe documentar un plan de despliegue y asegurarse de que se cumplen los requisitos apropiados antes del despliegue.
A.6.2.6	**Operación y seguimiento del sistema de IA.** La organización debe definir y documentar los elementos necesarios para la operación continuada del sistema de IA. Como mínimo, esto debería incluir el seguimiento del sistema y del desempeño, las reparaciones, las actualizaciones y el soporte.
A.6.2.7	**Documentación técnica del sistema de IA.** La organización debe determinar la documentación técnica del sistema de IA que es necesaria para cada categoría relevante de partes interesadas, como usuarios, socios, autoridades de supervisión, y proporcionarles la documentación técnica en la forma apropiada.
A.6.2.8	**Grabación de los registros de eventos del sistema de IA.** La organización debe determinar las etapas del ciclo de vida del sistema de IA en las que se debería habilitar la grabación de los registros de eventos, aunque, como mínimo, debería ser cuando el sistema de IA esté en uso.

A.7 Datos para sistemas de IA

Objetivo: Asegurar que la organización comprenda el rol y los impactos que tienen los datos en los sistemas de IA, tanto en la aplicación y desarrollo, como en la provisión o el uso de los sistemas de IA durante todo su ciclo de vida.

N.°	Control
A.7.2	**Datos para el desarrollo y la mejora del sistema de IA.** La organización debe definir, documentar e implementar procesos de gestión de datos con respecto al desarrollo de sistemas de IA.
A.7.3	**Adquisición de los datos.** La organización debe determinar y documentar los detalles sobre la adquisición y selección de los datos utilizados en los sistemas de IA.
A.7.4	**Calidad de los datos para los sistemas de IA.** La organización debe definir y documentar los requisitos de calidad de los datos, así como asegurarse de que los datos utilizados para desarrollar y operar con el sistema de IA cumplen dichos requisitos.
A.7.5	**Procedencia de los datos.** La organización debe definir y documentar un proceso para registrar la procedencia de los datos utilizados en sus sistemas de IA a lo largo de los ciclos de vida de los datos y del sistema de IA.
A.7.6	**Preparación de los datos.** La organización debe definir y documentar sus criterios para seleccionar las preparaciones de datos, así como los métodos de preparación de datos que serán utilizados.

A.8 Información para las partes interesadas de los sistemas de IA

Objetivo: Asegurar que las partes interesadas relevantes dispongan de la información necesaria para comprender y evaluar los riesgos y sus impactos (tanto positivos como negativos).

N.°	Control
A.8.2	**Documentación e información del sistema para los usuarios.** La organización debe determinar y proporcionar la información necesaria a los usuarios del sistema de IA.
A.8.3	**Reporte externo.** La organización debe proporcionar medios para que las partes interesadas notifiquen impactos adversos del sistema de IA.
A.8.4	**Comunicación de incidentes.** La organización debe determinar y documentar un plan para comunicar incidentes a los usuarios del sistema de IA.
A.8.5	**Información para las partes interesadas.** La organización debe determinar y documentar sus obligaciones de comunicación de información sobre el sistema de IA a las partes interesadas.

A.9 Uso de sistemas de IA

Objetivo: Asegurar que la organización utilice los sistemas de IA de forma responsable y según las políticas organizacionales.

N.°	Control
A.9.2	**Procesos para el uso responsable de los sistemas de IA.** La organización debe definir y documentar los procesos para el uso responsable de los sistemas de IA.
A.9.3	**Objetivos para el uso responsable del sistema de IA.** La organización debe identificar y documentar los objetivos que orienten el uso responsable de los sistemas de IA.
A.9.4	**Uso previsto del sistema de IA.** La organización debe asegurar que el sistema de IA se utiliza de acuerdo con los usos previstos del sistema de IA y su documentación asociada.

A.10 Relaciones con terceros y clientes

Objetivo: Asegurar que la organización comprenda sus responsabilidades y siga rindiendo cuentas, y que los riesgos se distribuyan apropiadamente cuando haya terceros involucrados en cualquier etapa del ciclo de vida del sistema de IA.

N.°	Control
A.10.2	**Asignación de responsabilidades.** La organización debe asegurar que las responsabilidades en el ciclo de vida de su sistema de IA se asignan entre la organización, sus socios, proveedores, clientes y terceros.
A.10.3	**Proveedores.** La organización debe establecer un proceso para asegurarse de que el uso que hace de los servicios, productos o materiales suministrados por los proveedores está en consonancia con el enfoque de la organización para el desarrollo y uso responsables de los sistemas de IA.
A.10.4	**Clientes.** La organización debe asegurar que su enfoque responsable para el desarrollo y uso de sistemas de IA tiene en cuenta las expectativas y necesidades de sus clientes.

ANEXO B (NORMATIVO) — GUÍA DE IMPLEMENTACIÓN DE LOS CONTROLES DE IA

B.1 Generalidades

La guía de implementación que se documenta en este anexo está relacionada con los controles que se enumeran en la tabla A.1. Proporciona información para apoyar la implementación de los controles enumerados en la tabla A.1 y para satisfacer el objetivo de control. Sin embargo, las organizaciones no tienen que documentar o justificar la inclusión o exclusión de la guía de implementación en la declaración de aplicabilidad (ver apartado 6.1.3).

La guía de implementación no siempre es adecuada o suficiente en todas las situaciones y no siempre satisface los requisitos de control específicos de la organización. La organización puede ampliar o modificar la guía de implementación o definir su propia implementación de un control de acuerdo con sus requisitos específicos y necesidades de tratamiento del riesgo.

Este anexo tiene que utilizarse como una guía para determinar e implementar controles para el tratamiento del riesgo de la IA en el sistema de gestión de la IA que se define en este documento. Se pueden determinar otros controles organizacionales y técnicos distintos a los que se incluyen en este anexo (ver el tratamiento del riesgo del sistema de gestión de la IA en el apartado 6.1.3). Este anexo se puede considerar como un punto de partida para desarrollar implementaciones de controles específicos de la organización.

B.2 Políticas relacionadas con la IA

B.2.1 Objetivo

Proporcionar dirección y apoyo en materia de gestión para los sistemas de IA, de acuerdo con los requisitos de negocio.

B.2.2 Política de IA

Control: La organización debería documentar una política para el desarrollo o el uso de sistemas de IA.

Guía de implementación: La política de IA se debería basar en:

- la estrategia de negocio;
- los valores y la cultura de la organización y la cantidad de riesgo que la organización está dispuesta a asumir o tolerar;
- el nivel de riesgo que representan los sistemas de IA;
- los requisitos legales, incluyendo contratos;
- el entorno de riesgo de la organización;
- el impacto para las partes interesadas relevantes (ver apartado 6.1.4).

La política de IA debería incluir (además de los requisitos en el apartado 5.2):

- los principios que guían todas las actividades de la organización con relación a la IA;
- los procesos para gestionar las desviaciones y las excepciones de la política.

La política de IA debería tener en cuenta aspectos específicos de cada tema cuando sea necesario para proporcionar una guía adicional o para proporcionar referencias cruzadas a otras políticas que traten esos aspectos. Algunos ejemplos de estos temas son:

- los recursos y activos de IA;
- las evaluaciones del impacto de los sistemas de IA (ver apartado 6.1.4);
- el desarrollo de los sistemas de IA.

Las políticas relevantes deberían guiar el desarrollo, la compra, la operación y el uso de los sistemas de IA.

B.2.3 Alineamiento con otras políticas organizacionales

Control: La organización debería determinar cuándo otras políticas pueden aplicarse a los objetivos de la organización con respecto a los sistemas de IA o verse afectadas por esos objetivos.

Guía de implementación: Hay muchos dominios que se entrecruzan con la IA, incluyendo la calidad, la seguridad, la protección de las personas y cosas y la privacidad. La organización debería considerar un análisis exhaustivo para determinar si las políticas actuales pueden entrecruzarse necesariamente y en qué aspectos, y

bien actualizar esas políticas si fueran necesarias las actualizaciones o bien incluir disposiciones al respecto en la política de IA.

Otra información: La política de IA debería fundamentarse en las políticas que el órgano de gobierno establezca en nombre de la organización. La Norma INTE/ISO/IEC 38507 proporciona una guía para que los miembros del órgano de gobierno de una organización posibiliten y gobiernen el sistema de IA durante todo su ciclo de vida.

B.2.4 Revisión de la política de IA

Control: La política de IA debería ser revisada a intervalos planificados o con una frecuencia adicional, según sea necesario, para asegurar su idoneidad, adecuación y eficacia continuas.

Guía de implementación: Un rol aprobado por la alta dirección debería ser el responsable del desarrollo, la revisión y la evaluación de la política de IA, o de sus componentes. La revisión debería incluir la evaluación de las oportunidades para la mejora de las políticas y el enfoque de la organización respecto a la gestión de los sistemas de IA en respuesta a los cambios del entorno de la organización, de las circunstancias del negocio, de las condiciones legales o del entorno técnico.

La revisión de la política de IA debería tener en cuenta los resultados de las revisiones de la alta dirección.

B.3 Organización interna

B.3.1 Objetivo

Establecer la rendición de cuentas dentro de la organización para mantener su enfoque responsable en la implementación, operación y gestión de los sistemas de IA.

B.3.2 Roles y responsabilidades en materia de IA

Control: Los roles y las responsabilidades en materia de IA deberían ser definidos y asignados de acuerdo con las necesidades de la organización.

Guía de implementación: La definición de roles y responsabilidades es crucial para asegurar la rendición de cuentas en toda la organización por su rol respecto al sistema de IA durante todo su ciclo de vida. Al asignar roles y responsabilidades, la

organización debería considerar las políticas de IA, los objetivos de IA y los riesgos identificados para asegurar que todas las áreas relevantes queden cubiertas.

Algunos ejemplos de las áreas que pueden requerir la definición de roles y responsabilidades pueden incluir:

- la gestión del riesgo;
- las evaluaciones del impacto del sistema de IA;
- la gestión de activos y recursos;
- la seguridad;
- la protección de las personas y cosas;
- la privacidad;
- el desarrollo;
- el desempeño;
- la supervisión humana;
- las relaciones con los proveedores;
- la demostración de la capacidad de cumplir los requisitos legales de forma consistente;
- la gestión de la calidad de los datos (durante todo el ciclo de vida).

Las responsabilidades de los diferentes roles deberían ser definidos hasta el nivel apropiado para que las personas desempeñen sus funciones.

B.3.3 Reporte de preocupaciones

Control: La organización debería definir y poner en marcha un proceso para reportar las preocupaciones sobre el rol de la organización con respecto a un sistema de IA durante todo su ciclo de vida.

Guía de implementación: El mecanismo de reporte debería cubrir las siguientes funciones:

a) contiene opciones de confidencialidad, de anonimato, o ambas; b) está disponible y se incentiva entre las personas empleadas y las contratadas temporalmente; c) está dotado con personal cualificado; d) estipula las facultades apropiadas de investigación y resolución para las personas indicadas en el punto c); e) proporciona

mecanismos para notificar y escalar el problema a la alta dirección de forma oportuna; f) proporciona una protección eficaz frente a represalias tanto para las personas implicadas en el reporte como para las que lo están en la investigación (por ejemplo, permitiendo que las notificaciones se hagan de forma confidencial y anónima); g) proporciona notificaciones según lo indicado en el apartado 4.4 y, si fuera apropiado, en el punto e), manteniendo al mismo tiempo la confidencialidad y el anonimato del punto a) y respetando las consideraciones generales de confidencialidad del negocio; h) proporciona mecanismos de respuesta con un plazo apropiado.

> ***Nota.*** *La organización puede utilizar los mecanismos de reporte ya existentes como parte de este proceso.*

Otra información: Además de la guía de implementación que se proporciona en este apartado, la organización debería tener en cuenta también la Norma INTE/ISO 37002.

B.4 Recursos para los sistemas de IA

B.4.1 Objetivo

Asegurar que la organización contabilice los recursos del sistema de IA (incluyendo los componentes y activos del sistema de IA) para así comprender y abordar plenamente los riesgos e impactos.

B.4.2 Documentación de los recursos

Control: La organización debería identificar y documentar los recursos relevantes que se requieren para las actividades en determinadas etapas del ciclo de vida del sistema de IA, así como para otras actividades relacionadas con la IA que sean relevantes para la organización.

Guía de implementación: La documentación de los recursos del sistema de IA es crucial para comprender los riesgos y los potenciales impactos del sistema de IA (tanto positivos como negativos) para las personas, los grupos de personas y la sociedad. Las evaluaciones del impacto del sistema de IA (ver apartado B.5) pueden basarse en la documentación de estos recursos.

Los recursos pueden incluir, sin carácter exhaustivo:

- los componentes del sistema de IA;

- los recursos de datos, es decir, los datos que se utilizan en cualquier etapa del ciclo de vida del sistema de IA;
- los recursos de herramientas (por ejemplo, algoritmos, modelos o herramientas de IA);
- los recursos de sistema y de computación (por ejemplo, hardware para desarrollar y ejecutar los modelos de IA, almacenamiento para los recursos de datos y de herramientas);
- los recursos humanos, es decir, personas con los conocimientos y experiencia necesarios (por ejemplo, para el desarrollo, las ventas, el entrenamiento, la operación y el mantenimiento del sistema de IA) con relación al rol de la organización durante todo el ciclo de vida del sistema de IA.

Los recursos pueden ser proporcionados por la propia organización, sus clientes o terceros.

Otra información: La documentación de los recursos también puede ayudar a determinar si hay recursos disponibles y, si no lo estuvieran, la organización debería revisar el diseño de la especificación del sistema de IA o los requisitos de despliegue.

B.4.3 Recursos de datos

Control: Como parte de la identificación de los recursos, la organización debería documentar la información acerca de los recursos de datos utilizados para el sistema de IA.

Guía de implementación: La documentación sobre los datos debería incluir, sin carácter exhaustivo, los siguientes aspectos:

- la procedencia de los datos;
- la fecha en la que se actualizaron o modificaron los datos por última vez;
- para el aprendizaje automático, las categorías de los datos (por ejemplo, datos de entrenamiento, de validación, de prueba y de producción);
- las categorías de los datos (por ejemplo, según se definen en la Norma ISO/IEC 19944-1);
- el proceso para el etiquetado de los datos;
- el uso previsto de los datos;

- la calidad de los datos (por ejemplo, según se describe en la serie de Normas ISO/IEC 5259);
- retención de datos aplicable y políticas de disposición o eliminación de datos;
- los sesgos conocidos o potenciales en los datos;
- la preparación de los datos.

B.4.4 Recursos de herramientas

Control: Como parte de la identificación de los recursos, la organización debería documentar información acerca de los recursos de herramientas usados por el sistema de IA.

Guía de implementación: Los recursos de herramientas para un sistema de IA y en particular para el aprendizaje automático pueden incluir, sin carácter exhaustivo:

- los tipos de algoritmos y los modelos de aprendizaje automático;
- las herramientas o procesos de acondicionamiento de datos;
- los métodos de optimización;
- los métodos de evaluación;
- las herramientas de aprovisionamiento para los recursos;
- las herramientas de ayuda para el desarrollo de modelos;
- el software y el hardware para el diseño, el desarrollo y el despliegue del sistema de IA.

Otra información: La Norma ISO/IEC 23053 proporciona una guía detallada sobre los tipos, métodos y enfoques para diferentes recursos de herramientas para el aprendizaje automático.

B.4.5 Recursos del sistema y de computación

Control: Como parte de la identificación de los recursos, la organización debería documentar información acerca de los recursos del sistema y de computación utilizados para el sistema de IA.

Guía de implementación: La información acerca de los recursos del sistema y de computación para un sistema de IA puede incluir, sin carácter exhaustivo:

- los requisitos de recursos del sistema de IA;
- los sitios en donde están ubicados los recursos del sistema y de computación (por ejemplo, en instalaciones propias [on-premises], computación en la nube o computación periférica [edge computing]);
- los recursos de procesamiento (incluyendo los de red y de almacenamiento);
- el impacto del hardware utilizado para ejecutar las cargas de trabajo del sistema de IA (por ejemplo, el impacto en el medio ambiente, bien mediante el uso o la fabricación del hardware o bien mediante el costo de utilización del hardware).

La organización debería tener en cuenta que pueden requerirse distintos recursos para permitir la mejora continua de los sistemas de IA.

> ***Nota.*** *La Norma INTE/ISO/IEC 22989 describe varias consideraciones sobre los recursos del sistema.*

B.4.6 Recursos humanos

Control: Como parte de la identificación de los recursos, la organización debería documentar información acerca de los recursos humanos y sus competencias utilizados para el desarrollo, despliegue, operación, gestión de cambios, mantenimiento, transferencia y retirada del servicio, así como la verificación e integración del sistema de IA.

Guía de implementación: La organización debería tener en cuenta la necesidad de conocimientos y experiencia diversos e incluir los tipos de roles que sean necesarios para el sistema. Los recursos humanos necesarios pueden incluir, sin carácter exhaustivo:

- los científicos de datos;
- los roles relacionados con la supervisión humana de los sistemas de IA;
- los expertos en temas de fiabilidad como seguridad, protección de las personas y cosas y privacidad;
- los investigadores y especialistas en IA, y los expertos de dominio que sean relevantes para los sistemas de IA.

Pueden ser necesarios distintos recursos en diferentes etapas del ciclo de vida del sistema de IA.

B.5 Evaluación de los impactos de los sistemas de IA

B.5.1 Objetivo

Evaluar los impactos del sistema de IA sobre las personas, los grupos de personas y la sociedad que se ven afectados por el sistema de IA durante todo su ciclo de vida.

B.5.2 Proceso de evaluación del impacto del sistema de IA

Control: La organización debería establecer un proceso para evaluar las consecuencias potenciales para las personas, los grupos de personas y la sociedad, que pueden derivarse del sistema de IA durante todo su ciclo de vida.

Guía de implementación: Dado que los sistemas de IA potencialmente generan un impacto significativo sobre las personas, los grupos de personas y la sociedad, la organización que proporciona y utiliza estos sistemas debería evaluar los impactos potenciales de estos sistemas sobre esos grupos, basándose en el propósito y uso previstos de dichos sistemas.

La organización debería considerar si un sistema de IA afecta a:

- la situación legal o a las oportunidades vitales de las personas;
- el bienestar físico o psicológico de las personas;
- los derechos humanos universales;
- la sociedad.

Los procedimientos de la organización deberían incluir, sin carácter exhaustivo:

a) las circunstancias en las que se debería realizar una evaluación del impacto del sistema de IA, las cuales pueden incluir:

1. la criticidad del propósito previsto y el contexto en el que se usa el sistema de IA o cualquier tipo de cambios significativos que puedan sufrir;
2. la complejidad de la tecnología de IA y el nivel de automatización de los sistemas de IA o cualquier tipo de cambios significativos que puedan sufrir;
3. la sensibilidad de los tipos de datos y sus fuentes que procesa el sistema de IA o cualquier tipo de cambio significativo que puedan sufrir;

b) los elementos que son parte del proceso de evaluación del impacto del sistema de IA, los cuales pueden incluir:

1. la identificación (por ejemplo, fuentes, eventos y resultados);
2. el análisis (por ejemplo, consecuencias y probabilidad);
3. la evaluación (por ejemplo, decisiones de aceptación y priorización);
4. el tratamiento (por ejemplo, medidas de mitigación);
5. la documentación, el reporte y la comunicación;

c) quién realiza la evaluación del impacto del sistema de IA; d) cómo se puede usar la evaluación del impacto del sistema de IA; e) las personas y la sociedad que pueden verse potencialmente impactadas según el propósito, el uso y las características previstos del sistema.

Otra información: Para algunas disciplinas u organizaciones, la consideración detallada del impacto sobre las personas, los grupos de personas y la sociedad forma parte de la gestión del riesgo, especialmente en disciplinas como la seguridad de la información, la protección de las personas y cosas y la gestión ambiental.

> ***Nota.*** *La Norma ISO/IEC 23894 describe cómo una organización puede realizar análisis de impacto sobre la propia organización, junto con evaluaciones sobre las personas, los grupos de personas y la sociedad, como parte de un proceso global de gestión del riesgo.*

B.5.3 Documentación de las evaluaciones del impacto del sistema de IA

Control: La organización debería documentar los resultados de las evaluaciones del impacto del sistema de IA y conservar los resultados durante un periodo de tiempo determinado.

Guía de implementación: Los elementos que la organización debería considerar documentar pueden incluir, sin carácter exhaustivo:

- el uso previsto del sistema de IA y cualquier otro uso indebido razonablemente previsible del sistema de IA;
- los impactos positivos y negativos del sistema de IA sobre las personas, los grupos de personas y la sociedad relevantes;

- los fallos predecibles, sus impactos potenciales y las medidas adoptadas para mitigarlos;
- los grupos demográficos relevantes a los que el sistema sea de aplicación;
- la complejidad del sistema;
- el papel del humano en las relaciones con el sistema, disponible para evitar impactos negativos, incluyendo las capacidades de supervisión humana, los procesos y las herramientas;
- el empleo y la capacitación del personal.

B.5.4 Evaluación del impacto del sistema de IA sobre las personas o grupos de personas

Control: La organización debería evaluar y documentar los impactos potenciales de los sistemas de IA sobre las personas o grupos de personas durante todo el ciclo de vida del sistema.

Guía de implementación: Cuando se evalúan los impactos sobre las personas, los grupos de persona y la sociedad, la organización debería considerar sus principios de gobernanza, políticas de IA y objetivos. Deberían tenerse en cuenta las necesidades específicas de protección de grupos como los niños, las personas con discapacidad, las personas mayores y los trabajadores.

Dependiendo del alcance del propósito y uso del sistema, las áreas de impacto que hay que considerar como parte de la evaluación incluyen, sin carácter exhaustivo:

- la equidad;
- la rendición de cuentas;
- la transparencia y la explicabilidad;
- la seguridad y la privacidad;
- la protección de las personas y cosas y la salud;
- las consecuencias financieras;
- la accesibilidad;
- los derechos humanos.

Otra información: Cuando sea necesario, la organización debería consultar a expertos (por ejemplo, investigadores, expertos en la materia y usuarios) para comprender

plenamente los impactos potenciales del sistema de IA sobre las personas, los grupos de personas y la sociedad.

B.5.5 Evaluación de los impactos sociales de los sistemas de IA

Control: La organización debería evaluar y documentar los impactos sociales potenciales de sus sistemas de IA durante todo su ciclo de vida.

Guía de implementación: Los impactos sociales pueden variar ampliamente en función del contexto de la organización y de los tipos de sistemas de IA. Algunos ejemplos de estos impactos sociales potenciales pueden ser:

- la sostenibilidad ambiental (incluyendo los impactos sobre los recursos naturales y las emisiones de gases de efecto invernadero);
- los económicos (incluyendo el acceso a servicios financieros, las oportunidades de empleo, los impuestos, el comercio y la industria);
- el gobierno (incluyendo los procesos legislativos, la desinformación para sacar rédito político, la seguridad nacional, y los sistemas de justicia penal);
- la salud y la protección de las personas y cosas (incluyendo el acceso a la atención sanitaria, el diagnóstico y tratamiento médicos, y posibles daños físicos y psicológicos);
- las normas, tradiciones, cultura y valores (incluyendo la desinformación que conduce a sesgos o perjuicios para las personas, los grupos de personas y la sociedad).

Otra información: El desarrollo y uso de los sistemas de IA puede ser intensivo en computación, con los consiguientes impactos en la sostenibilidad medioambiental. La organización debería considerar los impactos de sus sistemas de IA dentro del contexto de sus objetivos y estrategias globales de sostenibilidad ambiental.

> ***Nota.*** *La norma INTE/ISO/IEC TR 24368 proporciona una visión general de alto nivel sobre las preocupaciones éticas y sociales con respecto a los sistemas y aplicaciones de IA.*

B.6 Ciclo de vida del sistema de IA

B.6.1 Guía sobre la gestión para el desarrollo de sistemas de IA

B.6.1.1 Objetivo

Asegurar que la organización identifique y documente objetivos e implemente procesos para el diseño y desarrollo responsables de sistemas de IA.

B.6.1.2 Objetivos para el desarrollo responsable del sistema de IA

Control: La organización debería identificar y documentar objetivos para guiar el desarrollo responsable de los sistemas de IA, así como tener en cuenta esos objetivos e integrar medidas para lograrlos en el ciclo de vida del desarrollo.

Guía de implementación: La organización debería identificar objetivos (ver apartado 6.2) que afecten a los procesos de diseño y desarrollo del sistema de IA. Estos objetivos deberían ser considerados en los procesos de diseño y desarrollo. Por ejemplo, si una organización define la “equidad” como uno de los objetivos, debería incorporarse en la especificación de requisitos, la adquisición de datos, el acondicionamiento de datos, el entrenamiento del modelo, la verificación y la validación, etc.

Otra información: Se están utilizando las técnicas de IA para aumentar las medidas de seguridad como la predicción de amenazas, detección y prevención de ataques de seguridad. El anexo C proporciona ejemplos de objetivos de la organización para la gestión del riesgo, que pueden ser útiles a la hora de determinar los objetivos para el desarrollo de sistemas de IA.

B.6.1.3 Procesos para el diseño y desarrollo responsables de sistemas de IA

Control: La organización debería definir y documentar los procesos específicos para el diseño y desarrollo responsables del sistema de IA.

Guía de implementación: El desarrollo responsable de procesos para sistemas de IA debería incluir la consideración, sin carácter exhaustivo, de lo siguiente:

- las etapas del ciclo de vida;
- los requisitos de pruebas y medios planificados para las pruebas;
- los requisitos de supervisión humana, incluyendo procesos y herramientas, especialmente cuando el sistema de IA puede impactar a personas físicas;

- en qué etapas se deberían realizar las evaluaciones del impacto del sistema de IA;
- las expectativas y reglas de los datos de entrenamiento;
- los conocimientos y experiencia requeridos o la formación para desarrolladores de sistemas de IA;
- los criterios de lanzamiento;
- las aprobaciones y firmas necesarias en varias etapas;
- el control de cambios;
- la usabilidad y controlabilidad;
- el involucramiento de partes interesadas.

B.6.2 Ciclo de vida del sistema de IA

B.6.2.1 Objetivo

Definir los criterios y requisitos para cada etapa del ciclo de vida del sistema de IA.

B.6.2.2 Requisitos y especificación del sistema de IA

Control: La organización debería especificar y documentar requisitos para nuevos sistemas de IA o mejoras sustanciales de los sistemas existentes.

Guía de implementación: La organización debería documentar la justificación para desarrollar un sistema de IA y sus metas. Algunos de los factores que deberían considerarse, documentarse y entenderse pueden incluir:

a) por qué se va a desarrollar el sistema de IA, por ejemplo, si está motivado por un caso de negocio, la solicitud de un cliente o una política gubernamental; b) cómo se puede entrenar el modelo y cómo se pueden lograr los requisitos de datos.

Se deberían especificar los requisitos del sistema de IA y estos deberían abarcar todo el ciclo de vida del sistema de IA.

Otra información: Los procesos para describir el ciclo de vida del sistema de IA se proporcionan en la Norma ISO/IEC 5338. Para más información sobre el diseño centrado en las personas para sistemas interactivos, ver la Norma INTE/ISO/IEC 9241-210.

B.6.2.3 Documentación del diseño y desarrollo del sistema de IA

Control: La organización debería documentar el diseño y desarrollo del sistema de IA sobre la base de los objetivos organizacionales, los requisitos documentados y los criterios de especificación.

Guía de implementación: Hay muchas decisiones de diseño que resultan necesarias para un sistema de IA, incluyendo, sin carácter exhaustivo:

- el enfoque de aprendizaje automático (por ejemplo, supervisado frente a no supervisado);
- el algoritmo de aprendizaje y el tipo de modelo de aprendizaje automático utilizados;
- la forma en que se pretende entrenar el modelo y cuál es la calidad de los datos;
- la evaluación y el refinamiento de modelos;
- los componentes de hardware y software;
- las amenazas de seguridad consideradas durante todo el ciclo de vida del sistema de IA (las amenazas de seguridad específicas para sistemas de IA incluyen el envenenamiento de datos, el robo de modelos o la ingeniería inversa de modelos);
- la interfaz y la presentación de salidas;
- la forma en que los humanos pueden interactuar con el sistema;
- las consideraciones de interoperabilidad y portabilidad.

B.6.2.4 Verificación y validación del sistema de IA

Control: La organización debería definir y documentar medidas de verificación y validación para el sistema de IA, así como especificar los criterios para su uso.

Guía de implementación: Las medidas de verificación y validación pueden incluir, sin carácter exhaustivo:

- las metodologías y herramientas de pruebas;
- la selección de datos de prueba y su representación del ámbito de uso previsto;
- los requisitos correspondientes a los criterios de lanzamiento.

La organización debería definir y documentar criterios de evaluación tales como, sin carácter exhaustivo:

- un plan para evaluar los componentes del sistema de IA y el sistema de IA en su conjunto para riesgos relacionados con los impactos en las personas, los grupos de personas y la sociedad;
- los requisitos de fiabilidad y protección física del sistema de IA, incluidas tasas de error aceptables para el desempeño del sistema de IA.

B.6.2.5 Despliegue del sistema de IA

Control: La organización debería documentar un plan de despliegue y asegurarse de que se cumplen los requisitos apropiados antes del despliegue.

Guía de implementación: El plan de despliegue debería incluir información sobre cómo el sistema de IA se integrará en el entorno operacional. El plan de despliegue puede incluir, sin carácter exhaustivo:

- los criterios de lanzamiento del sistema de IA;
- el proceso de aprobación para el despliegue;
- la estrategia de despliegue (por ejemplo, despliegue gradual o completo);
- los requisitos para la infraestructura y los recursos de soporte;
- los procedimientos para la supervisión y el mantenimiento del sistema de IA tras el despliegue.

B.6.2.6 Operación y seguimiento del sistema de IA

Control: La organización debería definir y documentar los elementos necesarios para la operación continuada del sistema de IA. Como mínimo, esto debería incluir el seguimiento del sistema y del desempeño, las reparaciones, las actualizaciones y el soporte.

Guía de implementación: La organización debería definir criterios de desempeño para los sistemas de IA en funcionamiento. Los criterios de desempeño para los sistemas de IA en funcionamiento deberían estar determinados por la tarea en cuestión, como la clasificación, la regresión, la ordenación, el agrupamiento o la reducción de dimensionalidad.

Los criterios de desempeño pueden incluir aspectos estadísticos como tasas de error y duración del procesamiento. Para cada criterio, la organización debería identificar todas las métricas relevantes, así como las interdependencias entre métricas.

Se puede utilizar el modelo de calidad de la Norma ISO/IEC 25059 para definir criterios de desempeño.

B.6.2.7 Documentación técnica del sistema de IA

Control: La organización debería determinar la documentación técnica del sistema de IA que es necesaria para cada categoría relevante de partes interesadas, como usuarios, socios, autoridades de supervisión, y proporcionarles la documentación técnica en la forma apropiada.

Guía de implementación: La documentación técnica del sistema de IA puede incluir, sin carácter exhaustivo, los siguientes elementos:

- una descripción general del sistema de IA incluyendo su propósito previsto;
- las instrucciones de uso;
- las asunciones técnicas sobre su despliegue y operación;
- las limitaciones técnicas (por ejemplo, tasas de error aceptables, precisión, fiabilidad, robustez);
- las capacidades y funciones de supervisión que permiten a los usuarios u operadores influir en el funcionamiento del sistema.

Los elementos documentales relativos a todas las etapas del ciclo de vida del sistema de IA pueden incluir, sin carácter exhaustivo:

- la especificación del diseño y la arquitectura del sistema;
- las elecciones de diseño realizadas y las medidas de calidad adoptadas durante el proceso de desarrollo del sistema;
- la información sobre los datos utilizados durante el desarrollo del sistema;
- las asunciones hechas y las medidas de calidad adoptadas sobre la calidad de los datos;
- las actividades de gestión (por ejemplo, la gestión del riesgo) realizadas durante el desarrollo u operación del sistema de IA;
- los registros de verificación y validación;
- los cambios realizados en el sistema de IA cuando está en funcionamiento;
- la documentación de la evaluación del impacto según se describe en el capítulo B.5.

B.6.2.8 Grabación de los registros de eventos del sistema de IA

Control: La organización debería determinar las etapas del ciclo de vida del sistema de IA en las que se debería habilitar la grabación de los registros de eventos, aunque, como mínimo, debería ser cuando el sistema de IA esté en uso.

Guía de implementación: La organización debería asegurarse de que el registro que despliegue para los sistemas de IA recopile y registre automáticamente los registros de eventos relativos a ciertos eventos que ocurran durante la operación del sistema. Dicho registro puede incluir, sin carácter exhaustivo:

- la trazabilidad de la funcionalidad del sistema de IA para asegurar que el sistema de IA está operando según lo previsto;
- la detección del desempeño del sistema de IA fuera de sus condiciones de funcionamiento previstas que pueda dar lugar a un desempeño no deseado sobre los datos de producción o a impactos en las partes interesadas relevantes mediante la supervisión del funcionamiento del sistema de IA.

Los registros de eventos del sistema de IA pueden incluir información como la fecha y hora cada vez que se usa el sistema de IA, los datos de producción en los que opera el sistema de IA, las salidas que quedan fuera del rango del funcionamiento previsto del sistema de IA, etc.

Los registros de eventos deberían mantenerse durante el tiempo que sea necesario para el uso previsto del sistema de IA y conforme a lo establecido en las políticas de retención de datos de la organización.

Otra información: Algunos sistemas de IA, como los sistemas de identificación biométrica, pueden tener requisitos adicionales de registro dependiendo de la jurisdicción.

B.7 Datos para sistemas de IA

B.7.1 Objetivo

Asegurar que la organización comprenda el rol y los impactos que tienen los datos en los sistemas de IA, tanto en la aplicación y desarrollo, como en la provisión o el uso de los sistemas de IA durante todo su ciclo de vida.

B.7.2 Datos para el desarrollo y la mejora del sistema de IA

Control: La organización debería definir, documentar e implementar procesos de gestión de datos con respecto al desarrollo de sistemas de IA.

Guía de implementación: La gestión de datos puede incluir varios aspectos, como son, sin carácter exhaustivo:

- las implicaciones de privacidad y seguridad debido al uso de datos, algunos de los cuales pueden ser de naturaleza sensible;
- las amenazas a la protección de las personas y cosas y la seguridad que puedan surgir del desarrollo de sistemas de IA dependientes de los datos;
- los aspectos de transparencia y explicabilidad, incluyendo el origen de los datos y la capacidad de proporcionar una explicación de cómo se utilizan los datos para determinar la salida de un sistema de IA si el sistema requiere transparencia y explicabilidad;
- la representatividad de los datos de entrenamiento en comparación con el ámbito operacional de uso;
- la precisión e integridad de los datos.

> ***Nota.*** *En la Norma INTE/ISO/IEC 22989 puede encontrarse información detallada sobre los conceptos del ciclo de vida de un sistema de IA y la gestión de los datos.*

B.7.3 Adquisición de los datos

Control: La organización debería determinar y documentar los detalles sobre la adquisición y selección de los datos utilizados en los sistemas de IA.

Guía de implementación: Los detalles sobre la adquisición de datos pueden incluir:

- las categorías de datos necesarias para los sistemas de IA;
- la cantidad de datos requerida;
- las fuentes de datos (por ejemplo, internas, de pago, compartidas, datos abiertos, datos sintéticos);
- las características de las fuentes de datos (por ejemplo, estáticas, dinámicas, recopiladas, generadas por ordenador);
- los datos demográficos y características de los interesados (por ejemplo, sesgos potenciales o conocidos u otros errores no aleatorios);

- el manejo previo de los datos (por ejemplo, usos previos de los datos, su conformidad con los requisitos de privacidad y seguridad);
- los derechos sobre los datos (por ejemplo, IIP, derechos de autor);
- los metadatos asociados (por ejemplo, detalles de etiquetado o mejora de datos);
- el origen de los datos.

Otra información: Para documentar los detalles sobre la adquisición y el uso de los datos, se pueden utilizar las categorías de datos y una estructura para el uso de datos de la Norma ISO/IEC 19944-1.

B.7.4 Calidad de los datos para los sistemas de IA

Control: La organización debería definir y documentar los requisitos de calidad de los datos, así como asegurarse de que los datos utilizados para desarrollar y operar el sistema de IA cumplen dichos requisitos.

Guía de implementación: La calidad de los datos utilizados para desarrollar y operar los sistemas de IA tiene un impacto potencialmente significativo en la validez de las salidas de estos sistemas. Para los sistemas de IA que utilizan el aprendizaje automático supervisado o semisupervisado es importante que la calidad de los datos de entrenamiento, validación, pruebas y producción se defina, mida y mejore cuanto sea posible.

Otra información: En la serie de Normas ISO/IEC 5259 sobre la calidad de los datos para análisis de datos y aprendizaje automático se facilita información adicional sobre la calidad de los datos. En el Informe Técnico ISO/IEC TR 24027 se facilita información adicional sobre los diferentes tipos de sesgo en los datos utilizados en sistemas de IA.

B.7.5 Procedencia de los datos

Control: La organización debería definir y documentar un proceso para registrar la procedencia de los datos utilizados en sus sistemas de IA a lo largo de los ciclos de vida de los datos y del sistema de IA.

Guía de implementación: Según la Norma ISO 8000-2, un registro del origen de los datos puede incluir información acerca de la creación, actualización, transcripción, abstracción, validación y transferencia del control de los datos. Adicionalmente, la

compartición de datos (sin transferencia de control) y las transformaciones de los datos pueden incluirse también en la procedencia de los datos.

B.7.6 Preparación de los datos

Control: La organización debe definir y documentar sus criterios para seleccionar las preparaciones de datos, así como los métodos de preparación de datos a utilizar.

Guía de implementación: Los datos utilizados en un sistema de IA necesitan normalmente una preparación que los haga utilizables para una tarea determinada de IA. Los métodos habituales de preparación y transformación de los datos utilizados en sistemas de IA incluyen:

- el estudio estadístico de los datos (por ejemplo, su distribución, media, mediana, desviación típica, rango, estratificación, muestreo) y los metadatos estadísticos;
- la limpieza (es decir, la corrección de entradas, el tratamiento de entradas ausentes);
- la imputación (es decir, los métodos para completar las entradas ausentes);
- la normalización;
- el escalado;
- el etiquetado de las variables objetivo;
- la codificación (por ejemplo, la conversión de variables cualitativas a números).

> ***Nota.*** *Para información adicional sobre la preparación de datos específica para el aprendizaje automático, ver la serie de Normas ISO/IEC 5259 y la Norma ISO/IEC 23053.*

B.8 Información para las partes interesadas

B.8.1 Objetivo

Asegurar que las partes interesadas relevantes dispongan de la información necesaria para comprender y evaluar los riesgos y sus impactos (tanto positivos como negativos).

B.8.2 Documentación e información del sistema para los usuarios

Control: La organización debería determinar y proporcionar la información necesaria a los usuarios del sistema.

Guía de implementación: La información que puede proporcionarse a los usuarios incluye, sin carácter exhaustivo:

- el propósito del sistema;
- que el usuario está interactuando con un sistema de IA;
- cómo interactuar con el sistema;
- cómo y cuándo anular el sistema;
- los requisitos técnicos para la operación del sistema, incluyendo los recursos informáticos necesarios, y las limitaciones del sistema, así como su vida útil prevista;
- las necesidades de supervisión humana;
- la información sobre precisión y desempeño;
- información relevante proveniente de la evaluación del impacto, incluyendo los beneficios y perjuicios potenciales;
- los cambios en las afirmaciones sobre los beneficios del sistema;
- las actualizaciones y los cambios en el funcionamiento del sistema;
- la información de contacto;
- el material de formación para el uso del sistema.

B.8.3 Reporte externo

Control: La organización debería facilitar medios para que las partes interesadas notifiquen impactos adversos del sistema de IA.

Guía de implementación: Si bien debería supervisarse el funcionamiento del sistema para detectar problemas y fallos, la organización también debería proporcionar medios para que los usuarios u otras partes externas notifiquen efectos adversos (por ejemplo, la falta de equidad).

B.8.4 Comunicación de incidentes

Control: La organización debería determinar y documentar un plan para comunicar incidentes a los usuarios del sistema.

Guía de implementación: Los incidentes relacionados con el sistema de IA pueden ser específicos del propio sistema de IA o referirse a la seguridad de la información o la privacidad (por ejemplo, una violación de seguridad de los datos). La organización debería conocer sus obligaciones en cuanto al reporte de incidentes a los usuarios y otras partes interesadas, en función del contexto en el que opere el sistema.

Los requisitos legales y la actividad de los reguladores pueden ser aplicables, lo que puede suponer requisitos específicos para:

- los tipos de incidentes que tienen que comunicarse;
- el plazo para el reporte;
- si tiene que notificarse a las autoridades y a cuáles de ellas;
- los detalles que deben comunicarse.

Otra información: Las Normas INTE/ISO/IEC 27001 e INTE/ISO/IEC 27701 proporcionan un mayor detalle sobre la gestión de incidentes de seguridad y privacidad respectivamente.

B.8.5 Información para las partes interesadas

Control: La organización debería determinar y documentar sus obligaciones de comunicación de información sobre el sistema de IA a las partes interesadas.

Guía de implementación: En ciertos casos, una jurisdicción puede requerir información sobre el sistema a compartir con autoridades como los reguladores. La información enviada puede incluir, por ejemplo:

- la documentación técnica del sistema, incluyendo, sin carácter exhaustivo, los conjuntos de datos para entrenamiento, validación y pruebas, así como las justificaciones sobre los algoritmos elegidos y los registros de validación y verificación;
- los riesgos relacionados con el sistema;
- los resultados de evaluaciones del impacto;
- los registros de tipo log y otros registros del sistema.

La organización debería comprender sus obligaciones al respecto y asegurarse de que se comparte la información apropiada con las autoridades relevantes.

B.9 Uso de sistemas de IA

B.9.1 Objetivo

Asegurar que la organización utiliza los sistemas de IA de forma responsable y conforme a las políticas organizacionales.

B.9.2 Procesos para el uso responsable de los sistemas de IA

Control: La organización debería definir y documentar los procesos para el uso responsable de los sistemas de IA.

Guía de implementación: Según su contexto, la organización puede tener varias razones para decidir si usar un sistema de IA en particular. Algunos ejemplos son:

- las aprobaciones requeridas;
- el costo (incluyendo el seguimiento y mantenimiento continuos);
- los requisitos aprobados para la contratación;
- los requisitos legales aplicables a la organización.

B.9.3 Objetivos para el uso responsable del sistema de IA

Control: La organización debería identificar y documentar objetivos para guiar el uso responsable de los sistemas de IA.

Guía de implementación: La organización puede tener diferentes expectativas y objetivos respecto a qué constituye un desarrollo responsable de sistemas de IA en función de los distintos contextos en los que opere. Algunos de estos objetivos incluyen:

- la equidad;
- la rendición de cuentas;
- la transparencia;
- la explicabilidad;

- la fiabilidad;
- la protección de las personas y cosas;
- la robustez y la redundancia;
- la privacidad y la seguridad;
- la accesibilidad.

Una vez definidos, la organización debería implementar mecanismos para lograr sus objetivos. La organización debería determinar en qué etapas del ciclo de vida del sistema de IA se deberían incorporar objetivos significativos de supervisión humana. Estos pueden incluir:

- involucrar a revisores humanos para verificar las salidas del sistema de IA, incluyendo que tengan la autoridad para anular decisiones tomadas por el sistema de IA;
- asegurar que la supervisión humana está incluida si fuera necesaria para el uso aceptable del sistema de IA;
- realizar el seguimiento del desempeño del sistema de IA, incluyendo la precisión de las salidas del sistema de IA;
- notificar preocupaciones relacionadas con las salidas del sistema de IA y su impacto en las partes interesadas relevantes;
- notificar preocupaciones relativas a cambios en el desempeño o la capacidad del sistema de IA de producir salidas correctas a partir de los datos en producción;
- considerar si la toma de decisiones automatizada es apropiada para un enfoque responsable del uso de un sistema de IA y para el uso previsto del sistema de IA.

Otra información: El anexo C proporciona ejemplos de objetivos organizacionales para la gestión del riesgo, que pueden ser útiles para determinar los objetivos sobre el uso del sistema de IA.

B.9.4 Uso previsto del sistema de IA

Control: La organización debería asegurar que el sistema de IA se utiliza de acuerdo con los usos previstos de dicho sistema y de la documentación que le acompaña.

Guía de implementación: El sistema de IA debería ser desplegado de acuerdo con las instrucciones del sistema de IA y otra documentación asociada a él (ver apartado B.8.2). La operación del sistema de IA debería ser objeto de seguimiento (ver apartado

B.6.2.6). La organización debería mantener registros de eventos u otra documentación relativa al despliegue y a la operación del sistema de IA que puedan servir para demostrar que el sistema de IA se está usando según lo previsto.

B.10 Relaciones con terceros y clientes

B.10.1 Objetivo

Asegurar que la organización comprenda sus responsabilidades y siga rindiendo cuentas, y que los riesgos se distribuyan apropiadamente cuando intervengan terceros en cualquier etapa del ciclo de vida del sistema de IA.

B.10.2 Asignación de responsabilidades

Control: La organización debería asegurar que las responsabilidades en el ciclo de vida de su sistema de IA se asignan entre la organización, sus socios, proveedores, clientes y terceros.

Guía de implementación: En el ciclo de vida de un sistema de IA, las responsabilidades pueden estar repartidas entre las partes que proporcionan los datos, las partes que proporcionan los algoritmos y modelos, las partes que desarrollan o utilizan el sistema de IA y las que son responsables de la rendición de cuentas ante algunas o la totalidad de las partes interesadas. La organización debería documentar todas las partes que intervienen en el ciclo de vida del sistema de IA y sus roles, así como determinar sus responsabilidades.

En el caso de que la organización suministre un sistema de IA a un tercero, la organización debería asegurarse de que adopta un enfoque responsable para el desarrollo del sistema de IA.

Cuando los datos procesados incluyan IIP, las responsabilidades normalmente están repartidas entre los responsables de la IIP y los encargados de su tratamiento. La Norma INTE/ISO/IEC 29100 proporciona más información sobre los responsables de IIP y los encargados del tratamiento de IIP.

B.10.3 Proveedores

Control: La organización debería establecer un proceso para asegurarse de que el uso que hace de los servicios, productos o materiales suministrados por los proveedores

está en consonancia con el enfoque de la organización para el desarrollo y uso responsables de los sistemas de IA.

Guía de implementación: La organización debería considerar los siguientes aspectos en relación con sus proveedores:

- la evaluación de los riesgos asociados al uso de productos o servicios de proveedores en el sistema de IA;
- los requisitos contractuales para que los proveedores cumplan con las políticas de IA de la organización;
- la supervisión del desempeño de los proveedores en relación con los requisitos de IA;
- los procedimientos para gestionar los incidentes relacionados con los proveedores.

B.10.4 Clientes

Control: La organización debería asegurar que su enfoque responsable para el desarrollo y uso de sistemas de IA tiene en cuenta las expectativas y necesidades de sus clientes.

Guía de implementación: La organización debería considerar los siguientes aspectos en relación con sus clientes:

- la comunicación clara sobre las capacidades y limitaciones del sistema de IA;
- los mecanismos para recibir retroalimentación de los clientes sobre el desempeño del sistema de IA;
- el soporte para que los clientes utilicen el sistema de IA de manera responsable;
- la gestión de las expectativas de los clientes en relación con el sistema de IA.

ANEXO C (INFORMATIVO) — POTENCIALES OBJETIVOS ORGANIZACIONALES Y FUENTES DE RIESGO RELACIONADOS CON LA IA

C.1 Generalidades

Este anexo proporciona una lista no exhaustiva de potenciales objetivos organizacionales y fuentes de riesgo relacionados con la IA que pueden ser útiles para las organizaciones al establecer sus objetivos de IA (ver apartado 6.2) y al realizar evaluaciones del riesgo de la IA (ver apartado 6.1.2).

C.2 Potenciales objetivos organizacionales

Los potenciales objetivos organizacionales relacionados con la IA pueden incluir:

Fiabilidad del sistema de IA:

- Garantizar que el sistema de IA funciona de manera consistente y predecible dentro de los parámetros definidos.
- Asegurar que el sistema de IA produce resultados precisos y reproducibles.
- Minimizar los errores y fallos del sistema de IA.

Equidad:

- Asegurar que el sistema de IA no discrimina injustamente a personas o grupos de personas.
- Garantizar que el sistema de IA trata a todas las personas de manera equitativa.
- Identificar y mitigar los sesgos en los datos y algoritmos del sistema de IA.

Transparencia y explicabilidad:

- Proporcionar explicaciones comprensibles de las decisiones del sistema de IA.
- Documentar el funcionamiento del sistema de IA de manera clara y accesible.
- Permitir a los usuarios comprender cómo el sistema de IA llega a sus conclusiones.

Privacidad y seguridad:

- Proteger la información de identificación personal (IIP) procesada por el sistema de IA.
- Garantizar la seguridad de los datos utilizados por el sistema de IA.
- Cumplir con los requisitos legales de privacidad y protección de datos.

Protección de las personas y cosas:

- Asegurar que el sistema de IA no cause daños físicos o psicológicos a las personas.
- Identificar y mitigar los riesgos de seguridad asociados al sistema de IA.
- Garantizar que el sistema de IA opera de manera segura en su entorno de despliegue.

Rendición de cuentas:

- Establecer responsabilidades claras para el desarrollo, despliegue y operación del sistema de IA.
- Garantizar que existe supervisión humana adecuada del sistema de IA.
- Documentar las decisiones tomadas en relación con el sistema de IA.

Sostenibilidad:

- Minimizar el impacto ambiental del sistema de IA.
- Optimizar el uso de recursos computacionales del sistema de IA.
- Considerar el ciclo de vida completo del sistema de IA desde una perspectiva de sostenibilidad.

C.3 Potenciales fuentes de riesgo

Las potenciales fuentes de riesgo relacionadas con la IA pueden incluir:

Riesgos relacionados con los datos:

- Datos de entrenamiento sesgados o no representativos.
- Datos de baja calidad o incompletos.
- Violaciones de privacidad en el procesamiento de datos.

- Cambios en la distribución de los datos de producción respecto a los datos de entrenamiento.

Riesgos relacionados con el modelo:

- Sobreajuste o subajuste del modelo de IA.
- Falta de robustez del modelo ante perturbaciones o ataques adversariales.
- Comportamiento inesperado del modelo en situaciones no contempladas durante el entrenamiento.
- Degradación del rendimiento del modelo con el tiempo.

Riesgos relacionados con el despliegue:

- Integración inadecuada del sistema de IA en el entorno operacional.
- Falta de supervisión humana adecuada durante la operación.
- Cambios en el entorno operacional que afectan al rendimiento del sistema de IA.
- Uso del sistema de IA fuera de su ámbito de aplicación previsto.

Riesgos relacionados con las partes interesadas:

- Falta de comprensión por parte de los usuarios sobre las capacidades y limitaciones del sistema de IA.
- Expectativas no realistas sobre el rendimiento del sistema de IA.
- Resistencia al uso del sistema de IA por parte de los usuarios.
- Impactos negativos sobre grupos vulnerables o minoritarios.

Riesgos legales y de cumplimiento:

- Incumplimiento de requisitos legales aplicables al uso de la IA.
- Cambios en el marco regulatorio que afectan al sistema de IA.
- Responsabilidad legal por decisiones tomadas por el sistema de IA.
- Violaciones de derechos de propiedad intelectual en el desarrollo del sistema de IA.

Riesgos organizacionales:

- Falta de competencias y conocimientos especializados en IA.

- Dependencia excesiva de proveedores externos de IA.
- Falta de gobernanza y supervisión adecuada del sistema de IA.
- Conflictos entre los objetivos del sistema de IA y los valores organizacionales.

ANEXO D (INFORMATIVO) — USO DEL SISTEMA DE GESTIÓN DE LA IA EN DIFERENTES DOMINIOS O SECTORES

D.1 Generalidades

Este documento es aplicable a cualquier organización, independientemente de su tamaño, tipo y naturaleza, que provea o use productos o servicios que utilicen sistemas de IA. Este anexo proporciona orientación sobre cómo aplicar el sistema de gestión de la IA en diferentes dominios o sectores industriales.

Los requisitos de este documento son genéricos y están diseñados para ser aplicables a todas las organizaciones. Sin embargo, la aplicación de estos requisitos puede variar según el dominio o sector en el que opera la organización. Este anexo ilustra cómo los requisitos del sistema de gestión de la IA pueden adaptarse a contextos específicos.

D.2 Sector sanitario

En el sector sanitario, los sistemas de IA se utilizan para una variedad de aplicaciones, incluyendo el diagnóstico médico, la planificación del tratamiento, la gestión de la atención al paciente y la investigación clínica. Las consideraciones específicas para este sector incluyen:

- La seguridad del paciente es una prioridad fundamental, y los sistemas de IA deben diseñarse y operarse para minimizar el riesgo de daño al paciente.
- Los sistemas de IA utilizados en diagnóstico o tratamiento médico pueden estar sujetos a regulaciones específicas de dispositivos médicos.
- La privacidad de los datos del paciente es de suma importancia, y los sistemas de IA deben cumplir con los requisitos de privacidad aplicables.

- La supervisión humana por parte de profesionales de la salud calificados es esencial para los sistemas de IA que apoyan decisiones clínicas.

D.3 Sector financiero

En el sector financiero, los sistemas de IA se utilizan para aplicaciones como la detección de fraude, la evaluación del crédito, el comercio algorítmico y el servicio al cliente. Las consideraciones específicas para este sector incluyen:

- Los sistemas de IA utilizados en la toma de decisiones financieras deben ser transparentes y explicables para cumplir con los requisitos regulatorios.
- La equidad en las decisiones de crédito y otros servicios financieros es una consideración importante para evitar la discriminación.
- Los sistemas de IA en el sector financiero pueden estar sujetos a regulaciones específicas de servicios financieros.
- La gestión del riesgo es fundamental en el sector financiero, y los sistemas de IA deben integrarse en los marcos de gestión del riesgo existentes.

D.4 Sector del transporte

En el sector del transporte, los sistemas de IA se utilizan para aplicaciones como los vehículos autónomos, la gestión del tráfico, la logística y la seguridad. Las consideraciones específicas para este sector incluyen:

- La seguridad es una prioridad fundamental en el sector del transporte, y los sistemas de IA deben diseñarse para minimizar el riesgo de accidentes.
- Los sistemas de IA en vehículos autónomos pueden estar sujetos a regulaciones específicas de seguridad vial.
- La fiabilidad y robustez de los sistemas de IA son esenciales para garantizar la seguridad en el transporte.
- La supervisión humana puede ser necesaria en situaciones de alta criticidad o cuando el sistema de IA opera fuera de sus condiciones de diseño.

D.5 Sector de la administración pública

En el sector de la administración pública, los sistemas de IA se utilizan para aplicaciones como la prestación de servicios públicos, la toma de decisiones

administrativas y la seguridad pública. Las consideraciones específicas para este sector incluyen:

- La equidad y la no discriminación son consideraciones fundamentales en el uso de sistemas de IA en la administración pública.
- La transparencia y la rendición de cuentas son esenciales para mantener la confianza pública en los sistemas de IA utilizados por las administraciones públicas.
- Los sistemas de IA utilizados en decisiones que afectan a los derechos de los ciudadanos deben estar sujetos a supervisión humana adecuada.
- El cumplimiento de los requisitos legales y regulatorios es fundamental en el sector público.

D.6 Organizaciones pequeñas y medianas

Las organizaciones pequeñas y medianas (PYME) pueden enfrentar desafíos específicos al implementar un sistema de gestión de la IA, incluyendo recursos limitados y falta de conocimientos especializados. Las consideraciones específicas para las PYME incluyen:

- Las PYME pueden adoptar un enfoque simplificado para implementar el sistema de gestión de la IA, adaptando los requisitos a su tamaño y complejidad.
- Las PYME pueden beneficiarse de herramientas y guías específicas para facilitar la implementación del sistema de gestión de la IA.
- La colaboración con otras organizaciones o la contratación de servicios externos puede ayudar a las PYME a superar las limitaciones de recursos.
- Las PYME deben priorizar los controles más relevantes para sus sistemas de IA y contexto organizacional.

BIBLIOGRAFÍA

- ISO/IEC 22989:2022 — *Information technology — Artificial intelligence — Artificial intelligence concepts and terminology*
- ISO/IEC 23894:2023 — *Information technology — Artificial intelligence — Guidance on risk management*

- ISO/IEC 38507:2022 — *Information technology — Governance of IT — Governance implications of the use of artificial intelligence by organizations*
- ISO/IEC 5259-1 — *Data quality for analytics and machine learning (ML) — Part 1: Overview, terminology, and examples*
- ISO/IEC 5338 — *Information technology — Artificial intelligence — AI system life cycle processes*
- ISO/IEC 23053:2022 — *Framework for Artificial Intelligence (AI) Systems Using Machine Learning (ML)*
- ISO/IEC 25059 — *Software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Quality model for AI systems*
- ISO/IEC 19944-1:2020 — *Cloud computing and distributed platforms — Data flow, data categories and data use — Part 1: Fundamentals*
- ISO/IEC 27001:2022 — *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*
- ISO/IEC 27701:2019 — *Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines*
- ISO/IEC 29100:2011 — *Information technology — Security techniques — Privacy framework*
- ISO/IEC 9241-210:2019 — *Ergonomics of human-system interaction — Part 210: Human-centred design for interactive systems*
- ISO 31000:2018 — *Risk management — Guidelines*
- ISO 37002:2021 — *Whistleblowing management systems — Guidelines*
- ISO 8000-2:2022 — *Data quality — Part 2: Vocabulary*
- ISO/IEC TR 24027:2021 — *Information technology — Artificial intelligence (AI) — Bias in AI systems and AI aided decision making*
- ISO/IEC TR 24368:2022 — *Information technology — Artificial intelligence — Overview of ethical and societal concerns*
- NIST AI Risk Management Framework (AI RMF 1.0) — National Institute of Standards and Technology

---

© INTECO 2026 — Todos los derechos reservados